

norm

NEN-EN 50766

Cybersecurity requirements for tamper-resistant microprocessors and microcontrollers

Publicatie uitsluitend voor commentaar

januari 2026
ICS 35.030; 35.160

Commentaar vóór 2026-03-10

Als Europees normontwerp is gepubliceerd: prEN 50766:2026,IDT

Definitief vastgestelde normen zullen als Nederlandse norm gelden. Daarom wordt dit normontwerp in Nederland voor commentaar gepubliceerd. Op het ontwerp ingebracht commentaar zal aan de bevoegde normcommissie worden voorgelegd die hiermee rekening zal houden bij de bepaling van de Nederlandse stem. Indien er geen bezwaar bij NEN wordt gebracht, kan dat leiden tot ongewijzigde definitieve vaststelling van het ontwerp als norm.

Van Europese normen bestaan drie officiële versies: Engels, Frans en Duits. Voor Nederland zal de Engelse versie gelden. Daarnaast kan er gekozen worden voor een andere geautoriseerde versie in het Nederlands.

Normcommissie 381027 'Cybersecurity & Privacy'



THIS PUBLICATION IS COPYRIGHT PROTECTED

DEZE PUBLICATIE IS AUTEURSRECHTELIJK BESCHERMD

Apart from exceptions provided by the law, nothing from this publication may be duplicated and/or published by means of photocopy, microfilm, storage in computer files or otherwise, which also applies to full or partial processing, without the written consent of Stichting Koninklijk Nederlands Normalisatie Instituut.

Stichting Koninklijk Nederlands Normalisatie Instituut shall, with the exclusion of any other beneficiary, collect payments owed by third parties for duplication and/or act in and out of law, where this authority is not transferred or falls by right to Stichting Reprerecht.

Auteursrecht voorbehouden. Behoudens uitzondering door de wet gesteld mag zonder schriftelijke toestemming van Stichting Koninklijk Nederlands Normalisatie Instituut niets uit deze uitgave worden verveelvoudigd en/of openbaar gemaakt door middel van fotokopie, microfilm, opslag in computerbestanden of anderszins, hetgeen ook van toepassing is op gehele of gedeeltelijke bewerking.

Stichting Koninklijk Nederlands Normalisatie Instituut is met uitsluiting van ieder ander gerechtigd de door derden verschuldigde vergoedingen voor verveelvoudiging te innen en/of daartoe in en buiten rechte op te treden, voor zover deze bevoegdheid niet is overgedragen c.q. rechtens toekomt aan Stichting Reprerecht.

Although the utmost care has been taken with this publication, errors and omissions cannot be entirely excluded. Stichting Koninklijk Nederlands Normalisatie Instituut and/or the members of the committees therefore accept no liability, not even for direct or indirect damage, occurring due to or in relation with the application of publications issued by Stichting Koninklijk Nederlands Normalisatie Instituut.

Hoewel bij deze uitgave de uiterste zorg is nagestreefd, kunnen fouten en onvolledigheden niet geheel worden uitgesloten. Stichting Koninklijk Nederlands Normalisatie Instituut en/of de leden van de commissies aanvaarden derhalve geen enkele aansprakelijkheid, ook niet voor directe of indirecte schade, ontstaan door of verband houdend met toepassing van door Stichting Koninklijk Nederlands Normalisatie Instituut gepubliceerde uitgaven.

Ontwerp
Draft

EUROPEAN STANDARD
NORME EUROPÉENNE
EUROPÄISCHE NORM

DRAFT
prEN 50766

January 2026

ICS 35.030; 35.160

English Version

**Cybersecurity requirements for tamper-resistant
microprocessors and microcontrollers**

Exigences de cybersécurité pour les microprocesseurs et
microcontrôleurs sécurisés avec ou sans environnement
d'application ou système d'exploitation

Cybersicherheitsanforderungen für sichere
Mikroprozessoren und Mikrocontroller mit oder ohne
Anwendungsumgebung oder Betriebssystem

This draft European Standard is submitted to CENELEC members for enquiry.
Deadline for CENELEC: 2026-04-10.

It has been drawn up by CLC/TC 47X.

If this draft becomes a European Standard, CENELEC members are bound to comply with the CEN/CENELEC Internal Regulations which stipulate the conditions for giving this European Standard the status of a national standard without any alteration.

This draft European Standard was established by CENELEC in three official versions (English, French, German).
A version in any other language made by translation under the responsibility of a CENELEC member into its own language and notified to the CEN-CENELEC Management Centre has the same status as the official versions.

CENELEC members are the national electrotechnical committees of Austria, Belgium, Bulgaria, Croatia, Cyprus, the Czech Republic, Denmark, Estonia, Finland, France, Germany, Greece, Hungary, Iceland, Ireland, Italy, Latvia, Lithuania, Luxembourg, Malta, the Netherlands, Norway, Poland, Portugal, Republic of North Macedonia, Romania, Serbia, Slovakia, Slovenia, Spain, Sweden, Switzerland, Türkiye and the United Kingdom.

Recipients of this draft are invited to submit, with their comments, notification of any relevant patent rights of which they are aware and to provide supporting documentation.

Warning : This document is not a European Standard. It is distributed for review and comments. It is subject to change without notice and shall not be referred to as a European Standard.



European Committee for Electrotechnical Standardization
Comité Européen de Normalisation Electrotechnique
Europäisches Komitee für Elektrotechnische Normung

CEN-CENELEC Management Centre: Rue de la Science 23, B-1040 Brussels

Contents

Page

17	European foreword	5
18	1 Scope	6
19	2 Normative references	6
20	3 Terms and definitions	6
21	4 Symbols and abbreviated terms	8
22	5 Application of this document	9
23	5.1 General.....	9
24	5.2 Technical requirement structure and common application instructions	9
25	5.2.1 Requirement.....	9
26	5.2.2 Implementation options	9
27	5.2.3 Applicability.....	9
28	5.2.4 Assessment.....	9
29	5.2.5 Assessment verdict.....	10
30	5.2.6 Assessment evidence	11
31	6 Product context	11
32	6.1 Product's intended and reasonably foreseeable use	11
33	6.2 Product's functions	12
34	6.3 Product's operational environment of use	12
35	6.4 Product's system overview	12
36	6.5 Product's user.....	13
37	6.6 Product's reasonably foreseeable misuse.....	13
38	7 Vulnerability handling activities and outcomes — TR_VUL Vulnerability handling process	13
39		13
40	7.1 Requirement.....	13
41	7.2 Applicability.....	14
42	7.3 Assessment.....	14
43	8 Product technical requirements	14
44	8.1 General.....	14
45	8.2 Technical requirements related to platform implementation.....	14
46	8.2.1 TR_IMP Implementation best practices.....	14
47	8.2.2 TR_EXP No known exploitable vulnerabilities	16
48	8.2.3 TR_CFG Secure configuration of platform	17
49	8.3 Technical requirements related to platform functionalities	18
50	8.3.1 TR_PID Identification of platform.....	18
51	8.3.2 TR_PAU Authentication of platform	21
52	8.3.3 TR_INI Secure initialisation support.....	23
53	8.3.4 TR_SUP Secure update of platform	27
54	8.3.5 TR_SUD Secure update of dependent components	31
55	8.3.6 TR_ERA Secure erasure of data	33
56	8.3.7 TR_ISO Isolation mechanisms	35
57	8.3.8 TR_ACC Access control to security functionalities	38
58	8.3.9 TR_STO Secure storage.....	40
59	8.3.10 TR_COM Secure communications	45
60	8.3.11 TR_CRY Secure cryptographic features	49
61	8.3.12 TR_REP Reporting of security events	50
62	8.3.13 TR_AVB Advanced availability support of basic and essential functions	53
63	8.3.14 SRD_RST Reset of platform to initial state	55
64	8.3.15 TR_RES Tamper-resistance of platform.....	57
65	8.4 Technical requirements related to platform operation	61
66	8.4.1 TR_SEG Application of platform security guidance	61
67	Annex A (informative) Security analysis	63

68	A.1	General	63
69	A.2	Assets	64
70	A.3	Security incidents.....	65
71	A.3.1	General	65
72	A.3.2	PI_DUD Disclosure of user data	65
73	A.3.3	PI_MUD Manipulation of user data	65
74	A.3.4	PI_MBD Modification of the behaviour of the device	65
75	A.3.5	PI_MCD Malicious control of the device	65
76	A.3.6	PI_UEB Unavailability of essential and basic functions of the device	65
77	A.3.7	PI_MDO Malicious use of the device against other devices or networks	65
78	A.3.8	Completeness of incidents identification	65
79	A.4	Security problem definition	66
80	A.4.1	General	66
81	A.4.2	Threats.....	66
82	A.4.3	Organizational security policies	67
83	A.4.4	Security assumptions	67
84	A.4.5	Risks analysis coverage.....	68
85	A.5	Security objectives.....	68
86	A.5.1	General	68
87	A.5.2	Security objectives for the platform	68
88	A.5.3	Security objectives for the environment.....	69
89	A.5.4	Security problem definition coverage.....	69
90	A.5.5	Security objectives coverage.....	70
91	A.6	Risk environments	72
92	A.6.1	General	72
93	A.6.2	Example of platform risk environment (attack potential) information reuse	72
94	Annex B (informative)	Platform categories and applicability overview	74
95	Annex C (informative)	Support of European security evaluation methodologies	77
96	C.1	General	77
97	C.2	Compliance demonstration support.....	77
98	C.2.1	Assessment of applicability	77
99	C.2.2	TR_IMP Implementation best practices	77
100	C.2.3	TR_EXP No known exploitable vulnerabilities	77
101	C.2.4	TR_CFG Secure configuration of platform	78
102	C.2.5	TR_PID Identification of platform	78
103	C.2.6	TR_PAU Authenticity of platform	79
104	C.2.7	TR_INI Secure initialisation support.....	79
105	C.2.8	TR_SUP Secure update of platform.....	80
106	C.2.9	TR_SUD Secure update of dependent component	82

107	C.2.10 TR_ERA Secure erasure of data	83
108	C.2.11 TR_ISO Isolation mechanisms	84
109	C.2.12 TR_ACC Access control to security functionalities	85
110	C.2.13 TR_STO Secure storage.....	86
111	C.2.14 TR_COM Secure communication	88
112	C.2.15 TR_CRY Secure cryptographic features	89
113	C.2.16 TR_REP Reporting of security events	90
114	C.2.17 TR_AVS Advanced availability support of basic and essential functions	91
115	C.2.18 TR_RST Reset of platform to initial state	92
116	C.2.19 TR_RES Tamper resistance of platform.....	93
117	C.2.20 TR_SEG Application of platform security guidance	94
118	C.3 SESIP profiles analysis of compliance support	94
119	Annex ZZ (informative) Relationship between this European Standard and the essential	
120	requirements of Regulation (EU) 2024/2847 aimed to be covered	99
121	Bibliography	102

European foreword

This document (prEN 50766:2026) has been prepared by CLC TC47X "semiconductors and trusted chips implementation".

This document is currently submitted to the Enquiry

The following dates are proposed:

- latest date by which the existence of this document has to be announced at national level (doa) dav + 6 months
- latest date by which this document has to be implemented at national level by publication of an identical national standard or by endorsement (dop) dav + 12 months
- latest date by which the national standards conflicting with this document have to be withdrawn (dow) dav + 36 months
(to be confirmed or modified when voting)

This document has been prepared under a standardization request addressed to CENELEC by the European Commission. The Standing Committee of the EFTA States subsequently approves these requests for its Member States.

For the relationship with EU Legislation, see informative Annex ZZ, which is an integral part of this document.

1 Scope

This document specifies the technical requirements for general-purposes tamper-resistant microprocessors and microcontrollers intended for integration into products that rely on them as a foundational security component. The microprocessors and microcontrollers in scope are designed for deployment in environments where the security features of the product integrating the platform are of importance, and where the threat landscape includes attackers with low but non-negligible attack potential, corresponding to AVA_VAN.2 to AVA_VAN.3 as defined in [13].

2 Normative references

The following documents are referred to in the text in such a way that some or all of their content constitutes requirements of this document. For dated references, only the edition cited applies. For undated references, the latest edition of the referenced document (including any amendments) applies.

prEN 40000-1-1:2025, *Cybersecurity requirements for products with digital elements - Vocabulary*

prEN 40000-1-3:2025, *Cybersecurity requirements for products with digital elements — Vulnerability handling*

3 Terms and definitions

For the purposes of this document, the terms and definitions given in prEN 40000-1-1:2025 and the following apply.

ISO and IEC maintain terminology databases for use in standardization at the following addresses:

— ISO Online browsing platform: available at <https://www.iso.org/obp/>

— IEC Electropedia: available at <https://www.electropedia.org/>

3.1

access control

mechanism granting permission to a subject on an object

3.2

application

dependent component that provides a direct service to the end-user

3.3

asset

data, code or function that needs protection to prevent loss or disruption caused by a potential incident

3.4

best practices for cryptography

measures based on cryptographic techniques that have been shown to provide appropriate security for the corresponding use case

3.5

dependent component

software or hardware component using a functionality of a platform and not providing any functionality to the platform

3.6

device

composition of a platform and dependent components

- 170 **3.7**
 171 **end-user**
 172 user of the device
- 173 **3.8**
 174 **external entity**
 175 any entity in interaction with the platform
- 176 **EXAMPLE** Application, other dependent components or devices in physical or logical interaction with the platform.
- 177 **3.9**
 178 **firmware**
 179 set of executable instructions which are optionally provided as a part of the platform and which can be immutable
 180 and/or mutable
- 181 **3.10**
 182 **isolation mechanism**
 183 in a system separated in parts, security mechanism regulating the accesses to assets between those different
 184 parts
- 185 **3.11**
 186 **physical attack**
 187 an attack requiring the close presence of the attacker to the platform
- 188 **3.12**
 189 **platform**
 190 tangible element (or assembly of tangible elements) at a minimum composed of a microprocessor or
 191 microcontroller implementing security functionalities
- 192 Note 1 to entry: Platforms can be non-application-specific.
- 193 **3.13**
 194 **platform code**
 195 code that is part of the implementation of the platform functionality
- 196 **3.14**
 197 **platform data**
 198 all data handled by the platform i.e. user data, user code and platform manufacturer data
- 199 **3.15**
 200 **platform manufacturer data**
 201 data owned by the platform manufacturer handled by the platform
- 202 **3.16**
 203 **potential incident**
 204 specific event that could occur due to a threat exploiting a vulnerability
- 205 **3.17**
 206 **risk**
 207 result from the likelihood and magnitude of each threat
- 208 **3.18**
 209 **security functionality**
 210 functionality provided by the platform to the dependent components for the protection of assets (for example
 211 but not limited to secure storage, cryptographic operations)

prEN 50766:2026 (E)**3.19****sensitive data**

data that if compromised could harm the security functionalities of the platform or of the environment of the platform

3.20**tamper-evidence**

security property of a platform intended to ensure the detection of logical and/or physical attacks leading to achievement of threats identified in the risk assessment

3.21**tamper-resistance**

security property of a platform intended to prevent the successful exploitation of vulnerabilities by logical and/or physical attacks leading to achievement of threats identified in the risk assessment

3.22**tamper-response**

security property of a platform intended to provide the ability to react to the detection of logical and/or physical attacks leading to achievement of threats identified in the risk assessment

3.23**threat**

potential circumstance or cause that could lead to an incident on the product that results in loss or disruption

Note 1 to entry: Loss and disruption might happen amongst others on the product or its environment.

3.24**update package**

bundle containing platform firmware and/or software code and/or data, potentially associated with metadata

3.25**user**

platform user

generic term to designate any of the entities that will make use of the platform (including end-user)

3.26**user code**

code implementing the dependent component

3.27**user data**

data owned by (or associated to) the user handled by the platform

4 Symbols and abbreviated terms

CPU central processing unit

MCU microcontroller

MPU microprocessor

PI potential incident

SA security assumption

SOE security objectives for the platform environment

SOP security objectives for the platform

SP security policy

TR technical requirement

5 Application of this document

5.1 General

This document determines a set of technical requirements to be implemented by platforms based on a generic security analysis detailed in Annex A as well as the applicability conditions and assessment criteria for each of the technical requirement.

In this document each technical requirement and associated information are presented in a dedicated clause that follows a consistent structure. The next clause explains that structure and provide application instructions common to all technical requirements where needed.

5.2 Technical requirement structure and common application instructions

5.2.1 Requirement

This subclause states the requirement to be implemented by the platform. It can cover one or several security aspects.

5.2.2 Implementation options

This subclause lists the approved implementation options for fulfilling each security aspect of the requirement clause.

5.2.3 Applicability

This subclause specifies the conditions under which the technical requirement applies.

Technical requirement applicability status is one of the followings:

- mandatory without exception;
- mandatory with authorized exceptions, subject to usage restrictions or delegation to other products;
- based on risk assessment in accordance with defined guidance.

In certain cases, individual security aspects of a requirement are subject to different applicability status.

5.2.4 Assessment

5.2.4.1 General

Each requirement is associated with assessment specifications structured according to the following subclauses.

NOTE Each technical requirement ensures that all data it relies on to ensure security are always protected. For example, if cryptographic keys or internal status flags are involved, their generation, import and/or storage is part of any technical requirement relying on them. Therefore, the security assessment of each technical requirement also covers secure handling at any time of all data involved in fulfilling the technical requirement.

5.2.4.2 Assessment objective

This assessment clause identifies the security property or capability to verify, ensuring that the assessment remains focused on the intent of the requirement.

5.2.4.3 Assessment preparation

This assessment clause specifies the information and/or resources to be prepared and provided as input for the assessment.

prEN 50766:2026 (E)**5.2.4.4 Assessment activities****5.2.4.4.1 General**

This assessment clause defines the assessment steps to be carried out, organized according to the following subclauses.

Annex C provides the analysis how existing evaluation methodologies can be used to cover the following assessment activities.

5.2.4.4.2 Input verification

This subclause specifies how to verify that the technical requirement is fulfilled based on input provided as part of the assessment preparation.

5.2.4.4.3 Functional testing

This subclause specifies the functional tests to be performed to verify the full implementation of the requirement, covering all security aspects.

The functional tests execution may be split between the developer and the assessor.

5.2.4.4.4 Resistance testing

This subclause defines the specific aspects of the resistance testing, such as:

- The attack scenario and relevant considerations to be applied;
- The implementation parts (e.g. mechanism, function, interface) to be targeted.

In accordance with those specific aspects, the resistance testing may apply the following common instructions:

- Consider the relevant attacks listed in [15] 5 ("Examples of attack methods") and/or [16] 5 ("Examples of attack methods") as part of the analysis and/or alternative attack methods recognized relevant for specific use cases or platform subcategories;
- Apply the attack potential level aligned with the applicable risk environment (see Clause A.6) using by default the attack rating calculation defined in [15] 4 ("Identification of factors") and/or [16] 4 ("Identification of factors"), and/or another calculation recognized relevant for specific use cases or platform subcategories.

The penetration testing is based on the identification of areas of concern and prioritization of tests based on vulnerability assessment.

5.2.5 Assessment verdict

This assessment clause defines the conditions under which the assessment is considered valid.

For technical requirements where applicability is established, the verdict is PASS if:

- The input verification justifications are all satisfied;
- All applicable functional tests produce results consistent with the specified outputs;
- The resistance testing did not succeed in compromising the technical requirement.

For mandatory technical requirements where applicability exceptions are claimed, the verdict is PASS if required corresponding security guidelines are addressed in 8.4.1.

In all cases, the verdict is FAIL if:

- An applicable technical requirement is not implemented;
- Any of the conditions for a PASS verdict are not fulfilled.

5.2.6 Assessment evidence

This assessment subclause defines the evidence that can be collected to demonstrate that the requirement has been assessed and fulfilled.

Such evidence include, where applicable:

- test or assessment reports showing the steps performed and results obtained;
- logs, configuration files, or audit traces demonstrating the implementation of the requirement;
- screenshots, captures, or console outputs confirming the correct execution or protection behaviour.

6 Product context

6.1 Product's intended and reasonably foreseeable use

In this document, products refer to microcontrollers and microprocessors, also known as platforms, that are designed to be complemented with other components software and/or hardware to form a complete device. They are intended to be used across a wide range of industries and applications, able to support multiple end functions.

NOTE In some cases, particular configurations can be optimized for a specific final purpose, however fully closed platforms not intended to be completed to achieve a final function are outside the scope of this document.

Microcontrollers are typically compact, cost-sensitive, low-power, and integrating a CPU, memory and peripherals into a single package. This makes them fitting for small and simple systems, such as consumer and industrial devices (e.g. household appliances, toys, medical instruments, industrial machinery), IoT edge devices, sensors, actuators, low-cost automation, real-time processing tasks.

Microprocessors offer higher performance but usually do not include integrated memory or peripherals. They are suited for more complex systems that rely on rich operating systems, such as smartphones, tablets, consumer electronics, human-machine interfaces, networking and connectivity solution, computers, high-performance embedded systems (e.g. robotics, ECUs, medical imaging devices).

Additionally, the platforms covered in this document, are considered tamper-resistant, implementing protection against attacks with a potential corresponding to AVA_VAN.2 or AVA_VAN.3, as defined in [13]. They are then suitable for integration into devices that operate in environments where the threat landscape includes attackers with a low, but non-negligible, attack potential, whether through remote-only or physical access to the device.

Different categories of platforms can be defined based on the type of security functionalities they offer, which correspond to expected usage scenarios for integrating devices.

All platforms in scope at minimum belong to the following categories:

- Core security category (PTF-COR) – platforms that implement the essential mandatory security features forming the foundational baseline for platform-level protection.
- Medium tamper-resistance category (PTF-MTR) – platform that implement protection against logical and/or physical attacks with a potential corresponding to AVA_VAN.2 or AVA_VAN.3 as defined in [13].

Then, platforms may additionally belong to one or more of the following additional categories, depending on the extended security functionalities they provide:

- Advanced features category (PTF -ADV) - platforms that propose advanced internal features, intended to extend security functionalities for the use to other products, network or services, such as isolation, access control, advanced availability support, or reinitialization capabilities.
- Security services category (PTF-SER) - platforms that offer security functionalities on which higher level security services can be built, such as authenticity proof generation, cryptographic features, secure storage, secure communications, reporting of security events.

prEN 50766:2026 (E)

These last two categories support configurable combination of selectable security features (see Annex B). The selection of features for integration is determined by the product intended use case and the results of its risk assessment.

6.2 Product's functions

The essential function of platforms is to provide generic security functionalities to the dependent components via hardware and/or firmware and/or software. Platforms in scope of this document ensure protections against attacks with a potential corresponding to AVA_VAN.2 or AVA_VAN.3, as defined in [13].

Platforms are capable of independently implementing all applicable security functionalities necessary for their intended purpose, as determined by their risk assessment. However, certain specific aspects that are not relevant to the platforms are typically handled by the operating system or other external components.

- Automatic aspects of secure updates;
- Mechanisms for end-users to opt out of secure updates, including notifications and options to postpone updates;
- Mechanisms for end-users to opt out of reporting of security events.

6.3 Product's operational environment of use

Platforms environment consists of two distinct parts: logical and physical. Each part can be categorized as follows:

- Logical environment: this refers to software and hardware components outside the platform but that can interact with it, either directly through defined interfaces, or indirectly via shared resources such as memory or buses. The logical environment of the platform falls into one of the two categories:
 - Trusted logical environment (ENV-TRL): environment where the interacting components are not expected to intentionally compromise the platform (USR-TRE), or where no such components are present.
 - Untrusted logical environment (ENV-NTL): environment where the interacting components are considered potential vectors of attack (USR-NTE). In these environments, platforms from the PTF-ADV category that implement logical isolation from external component are required.
- Physical environment: this refers to users who have physical access to the platform. The physical environment of the platform falls into one of the two categories:
 - Trusted physical environment (ENV-TRP): environment where such users are not expected to intentionally attempt to compromise the platform (USR-TRI and USR-TRE).
 - Untrusted physical environment (ENV-NTP): environment where such users are considered potential attackers or vectors of attacks. In such environments, platforms belonging to the PTF-MTR category are required.

The environment categories to be selected depend on the integrating product use case and its corresponding risk assessment.

When platform includes a remote data processing solution, it is possible for the core platform and its remote part to operate in different environments. Each part therefore requires a distinct set of technical requirements aligned with the specific environment.

6.4 Product's system overview

Platforms in scope are composed of hardware and optionally firmware and/or operating system or application execution environment.

The platform is also optionally composed of a remote data processing solution under the responsibility of the platform manufacturer.

6.5 Product's user

Platforms in scope interact with one or several of the following category of users:

- Trusted intermediate users (USR-TRI): users operating within a development phase, before deployment to end-users, in which the platform is complemented with additional software and/or hardware layers to build the final device to be commercialized, such as manufacturers of end products. These users are considered trustworthy and are not expected to, or be used to, attempt compromising the platform. Such users may belong to any category of environment. All categories of platforms are suitable for use cases involving such users.

NOTE Intermediate users might not always be considered trustworthy by the platform manufacturer, who may choose to implement additional protections to ensure platform-related intellectual property. However, such concerns are outside the scope of this document.

- Trusted end-users (USR-TRE): legitimate users of the device integrating the platform, who are not expected to, or be used to, attempt corrupting their own device. Such users may belong to any category of environment. All categories of platforms are suitable for use cases involving such users.

- Untrusted end-users (USR-NTE): legitimate users of the device integrating the platform, who are considered potential attacker or vector of attacks, typically in scenarios where the device enforces restrictions on certain features. These users may attempt to bypass or compromise the platform security functionalities. Such users can only belong to environment categories ENV-NTP or ENV-NTL. The platform category PTF-MTR is required for use cases involving such users.

- Attackers (USR-ATT): individuals interacting with the device integrating the platform with the intent to compromise it, directly or via other components. Their attack potential of attack corresponds to AVA_VAN.2 and AVA_VAN.3 as defined in [13], depending on their level of access, respectively remote only or including physical access. Such users can only belong to environment categories ENV-NTP or ENV-NTL. The platform category PTF-MTR is required for use cases involving such users.

The user categories to be considered depend on the integrating product use case and its corresponding risk assessment.

6.6 Product's reasonably foreseeable misuse

For platforms in scope, the following categories of intentional or accidental misuses are reasonably foreseeable:

- Environment misuse (MIS-ENV): wrong category of platform is used regarding the environment identified during the integrating product risk assessment. This is relevant for all platform categories.
- User misuse (MIS-USR): wrong category of platform is used regarding the applicable users identified during the integrating product risk assessment. This is relevant for all platform categories.
- Integration misuse (MIS-INT): platform in scope is integrated without following the platform integration guidelines.

7 Vulnerability handling activities and outcomes — TR_VUL Vulnerability handling process

7.1 Requirement

A platform vulnerability handling process shall be put in place in compliance with prEN 40000-1-3:2025.

prEN 50766:2026 (E)

Given the intended risk environment for the platforms in scope, i.e. resistant to AVA_VAN.2 or AVA_VAN.3 attack potential as defined in [13], none of the requirement enhancements from prEN 40000-1-3:2025, 5.1.2.1 are required.

7.2 Applicability

This technical requirement is mandatory.

7.3 Assessment

All assessment aspects of this technical requirement are covered by prEN 40000-1-3:2025.

The verdict PASS is assigned to the assessment case if the assessment verdict for all requirements in prEN 40000-1-3:2025 are PASS.

8 Product technical requirements**8.1 General**

The technical requirements specified in this clause define what is to be implemented by the platform to fulfil its intended purpose. They have been established following a generic risk assessment for platforms described in Annex A. Therefore, the risk assessment specific to a platform can be constructed by refining the activities described in Annex A with platform specific information as follows:

- the platform context refines the information from 5.2.5 as needed;
- the platform assets list is established by refining the assets identified in Clause A.2 as needed;
- the incidents to be avoided are listed by refining the incidents identified in Clause A.3, with justification for any excluded incident;
- the expected risk environment of the platform from Clause A.6 is determined;
- the threats to be prevented are listed by refining the threats identified in A.4.2, with justification for any excluded threats.

The technical requirements presented in this clause are of three types:

- Technical requirements for the platform related to its implementation;
- Technical requirements for the platform, implemented by the platform itself which provide the expected security functionalities and the associated robustness protections;
- Technical requirements related to the operation of the platform which ensure either:
 - the security of the platform itself if the platform cannot ensure its self-protection, or
 - the security of assets of the platform or of assets exported to the environment.

The implementation of technical requirements is submitted to a security assessment to ensure their application, efficiency and robustness.

8.2 Technical requirements related to platform implementation**8.2.1 TR_IMP Implementation best practices****8.2.1.1 Requirement**

The platform implementation shall reflect the application of rules covering best practices for secure design and coding.

8.2.1.2 Implementation options

The best practices to be reflected in the platform implementation shall at minimum include the principles described in [1] 5.3.

8.2.1.3 Applicability

This technical requirement is by default mandatory.

However, exception applies in case of organizational constraints (e.g. legacy platforms) provided that the verdict to all applicable technical requirement is PASS.

8.2.1.4 Assessment

8.2.1.4.1 Assessment objective

The purpose of this assessment is to verify that the platform implementation design effectively ensures its security.

8.2.1.4.2 Assessment preparation

Platform user manual(s) including:

- the intended support provided by the platform to dependent components and/or other external entities; and
- description of all exposed interfaces, with their specific intended purpose and data parameters.

Assessment verdicts for all mandatory technical requirements and for those resulting from the risk assessment.

Platform implementation information in the form of description and/or source code and/or platform samples (representative of the product to be put on the market).

8.2.1.4.3 Assessment activities

8.2.1.4.3.1 Input verification

The input verification for each aspect of the implementation best practices requirement relies on the activities outlined in Table 1 below:

Table 1 — TR_IMP input verification activities

Requirement aspects	Verification activities
Efficiency of implementation best practices application	Analyse the platform implementation information to identify any deviation from the defined best practices. Analyse the assessment verdicts of applicable technical requirements from 8.3.

8.2.1.4.3.2 Functional testing

The incorrect application of the implementation best practices may lead to discrepancies in the platform implementation of technical requirements. Therefore, the functional testing of the implementation best practices relies on the verification of the functional testing of all applicable technical requirements from 8.3.

8.2.1.4.3.3 Resistance testing

The incorrect application of the implementation best practices may compromise the robustness of the platform implementation of technical requirements. Therefore, the resistance testing of the implementation best practices relies on the verification of the resistance testing of all applicable technical requirements from 8.3.

prEN 50766:2026 (E)**8.2.1.4.4 Assessment verdict**

The verdict is assigned as defined in 5.2.5.

Specifically, the verdict is FAIL if:

- any deviation from the defined best practices is detected during the input verification, and/or
- any applicable technical requirements from 8.3 receives a FAIL verdict.

8.2.1.4.5 Assessment evidence

Evidence as listed in 5.2.6.

8.2.2 TR_EXP No known exploitable vulnerabilities**8.2.2.1 Requirement**

The platform implementation shall not contain known exploitable vulnerabilities that are not excluded by the vulnerability risk assessment or addressed by specific user guidance to prevent their exploitation in the integrated product.

NOTE See details about vulnerability risk assessment in the vulnerability handling process referenced in Clause 7.

8.2.2.2 Implementation options

This technical requirement is addressed through the correct implementation of the technical requirements from 8.3, evidenced by their assessment results.

8.2.2.3 Applicability

This technical requirement is mandatory.

8.2.2.4 Assessment**8.2.2.4.1 Assessment objective**

The purpose of this assessment is to confirm that the platform implementation contains no known exploitable vulnerability that remain unaddressed.

8.2.2.4.2 Assessment preparation

Assessment verdict for all mandatory requirements and for those resulting from the risk assessment.

User guidance documentation.

8.2.2.4.3 Assessment activities**8.2.2.4.3.1 Input verification**

The input verification relies on the verification of the assessment status of all other applicable technical requirements.

8.2.2.4.3.2 Functional testing

The functional testing relies on the verification that the assessment status for all applicable technical requirements has been provided.

8.2.2.4.3.3 Resistance testing

The resistance testing relies on the verification that all applicable technical requirements have been successfully assessed.

8.2.2.4.4 Assessment verdict

The verdict is assigned as defined in 5.2.5.

8.2.2.4.5 Assessment evidence

Evidence as listed in 5.2.6.

8.2.3 TR_CFG Secure configuration of platform

8.2.3.1 Requirement

The platform shall be released in a secure configuration that protects the platform assets.

NOTE In case of integration into a device, the platform configuration might need to be updated by the integrator to protect all assets before being put on the market; this is covered in 8.4.1.

8.2.3.2 Implementation options

The secure configuration of platform requirement shall be implemented at minimum following principles described in [1], 5.4.

8.2.3.3 Applicability

This technical requirement is by default mandatory.

However, exception applies when the platform is delivered to an entity responsible for platform integration implementing organizational measures that ensure:

- the protection of platform assets during integration phase;
- the application of platform configurations from 8.4.1 required to protect platform assets prior to the release of the integrated product.

NOTE Information to be provided to the entity integrating the platform about organizational measures to be put in place is addressed in 8.4.1.

8.2.3.4 Assessment

8.2.3.4.1 Assessment objective

The purpose of this assessment is to confirm that the initial configuration of the platform provides adequate security for the designated receiving user and its environment.

8.2.3.4.2 Assessment preparation

Platform user manual(s) including the description of the platform default configuration.

Where applicable, description of organizational measures put in place with trusted integrator(s) to protect the platform during the integration phase.

Platform implementation information in the form of description and/or source code and/or platform samples (representative of the product to be put on the market).

8.2.3.4.3 Assessment activities

8.2.3.4.3.1 Input verification

The input verification for each aspect of the secure configuration requirement relies on the activities outlined in Table 2 below:

Table 2 — TR_CFG input verification activities

Requirement aspects	Verification activities
Secure configuration	Analyse the platform implementation information to verify that platform assets are fully protected in the platform initial configuration. Analyse the assessment verdicts of applicable technical requirements from 8.3, Alternatively, where applicability exception occurs, verify that required corresponding security guidelines are addressed in 8.4.1.

8.2.3.4.3.2 Functional testing

The incorrect application of the secure configuration of platform may lead to discrepancies in the platform activation or behaviour of security functionalities. Therefore, the functional testing of the secure configuration relies on the verification of the functional testing of all applicable technical requirements from 8.3.

8.2.3.4.3.3 Resistance testing

The incorrect application of the secure configuration of platform may compromise the robustness of the platform security functionalities. Therefore, the resistance testing of the secure configuration requirement relies on the verification of the resistance testing of all applicable technical requirements from 8.3.

8.2.3.4.4 Assessment verdict

The verdict is assigned as defined in 5.2.5.

8.2.3.4.5 Assessment evidence

Evidence as listed in 5.2.6.

8.3 Technical requirements related to platform functionalities**8.3.1 TR_PID Identification of platform****8.3.1.1 Requirement**

The platform shall be able to identify itself with at minimum a type and a version information, distinguishing it from other platforms.

Any change in any hardware and/or firmware and/or software part of the platform shall be reflected in its identification.

NOTE 1 The platform identity can consist of either a single identifier covering all platform components (e.g. hardware and firmware), or a combination of multiple distinct identifiers of individual platform components.

NOTE 2 This requirement does not require that unique instances of the platform can be distinguished apart.

8.3.1.2 Implementation options

The identification of platform shall be implemented using one of the options (black bullets) for each applicable requirement aspect specified in Table 3 below:

Table 3 — TR_PID implementation options

Requirement aspects	Requirement implementation options
Identification capability	— Identity information that: — is stored persistently, and

Requirement aspects	Requirement implementation options
	— is either provisioned during manufacturing and can be securely updatable where applicable according with 8.3.4, or delegated to the dependent component, and — is accessible to dependent components through publicly documented software and hardware interfaces. NOTE Disclosure of the platform identity information is subject to the policy of the dependent component. — Information referring at minimum to hardware identity physically engraved or labelled on the platform or, if not possible, provided on the packaging or in a document accompanying the platform; — Combination of above options.
Reflection of any change	— Single identifier representing the whole platform. A change will affect it, be either a hardware or a firmware change — A combination of identifiers making up the identification of platform. A change in hardware or firmware will affect only the relevant identifier

8.3.1.3 Applicability

This technical requirement is mandatory for platform category PTF-COR. Its primary function is to enable users to verify that the selected platform is the expected one.

8.3.1.4 Assessment

8.3.1.4.1 Assessment objective

The purpose of this assessment is to confirm that the exact name and version of platform can be accurately retrieved.

8.3.1.4.2 Assessment preparation

Description of how the uniqueness of the identification of platform is ensured and its expected value.

Platform implementation information in the form of description and/or source code and/or platform samples (representative of the product to be put on the market).

8.3.1.4.3 Assessment activities

8.3.1.4.3.1 Input verification

The input verification for each aspect of the identification of platform requirement relies on the activities outlined in Table 4 below.

Table 4 — TR_PID input verification activities

Requirement aspects	Verification activities
Uniquely identifiable	Verify that the description of the identification of platform feature justifies how the platform is uniquely identified, in accordance with the defined implementation options.
Reflection of any change	Verify that the description of the identification of platform feature justifies how platform versioning effectively support traceability of any change into the platform, in accordance with the defined implementation options. In case recognized versioning tools are used the requirement is met.

prEN 50766:2026 (E)**8.3.1.4.3.2 Functional testing**

The functional testing of each aspect of the identification of platform requirement includes at minimum the testing steps outlined in Table 5 below.

Table 5 — TR_PID functional testing activities

Requirement aspects	Verification steps
Uniquely identifiable	1. Execute the identification procedure, then: - Verify that the identity is included in the response and/or physically engraved or labelled on the platform; - Verify that the reported identity matches the platform description (refer to the input verification).
Reflection of any change	Covered by input verification

8.3.1.4.3.3 Resistance testing

The resistance level is assessed by conducting analysis and/or testing to ensure that the identification of platform mechanism is resistant to attacks, in accordance with instructions from 5.2.4.4.4 and based on the specific aspects described in following:

The relevant attack scenarios are those targeting the integrity of the platform identity where misrepresenting the platform identity has been identified as a risk.

EXAMPLE 1 The availability of the platform is critical, altering the identity could falsely indicate unavailability and disrupt the final service.

EXAMPLE 2 Identity is used for traceability purposes, such as during maintenance operations and product recalls.

In absence of such risk, only functional testing needs to be verified.

The confidentiality of the platform identity is not part of the verifications as the platform identity can be publicly accessible.

Such activities are expected to be applied across all relevant parts of the requirement implementation, including at minimum those listed in Table 6 below.

Table 6 — TR_PID resistance testing activities

Requirement aspects	Target of test/analysis
Identification of platform	— Exposed software and hardware interfaces related to identification of platform feature; — Persistent storage of platform identity; — Runtime access of platform identity; — Handling of all security parameters, cryptographic (e.g. keys) or not (e.g. flags, configuration parameters, state information, permission information), associated with protection of identity integrity, at minimum during persistent storage, loading and storage in volatile memory, and active processing.
Reflection of any change	Covered by input verification

8.3.1.4.4 Assessment verdict

The verdict is assigned as defined in 5.2.5.

8.3.1.4.5 Assessment evidence

Evidence as listed in 5.2.6.

8.3.2 TR_PAU Authentication of platform

8.3.2.1 Requirement

The platform shall implement functionality to external entity to prove its authenticity.

8.3.2.2 Implementation options

The authentication of platform requirement shall be implemented using one of the options (black bullets) for each applicable requirement aspect specified in Table 7 below.

Table 7 — TR_PAU implementation options

Requirement aspects	Implementation options
Platform authenticity proof	— Authenticity proof directly stored in platform, such as but not limited to: — Secret stored in persistent memory, fuses or hardware registers; — Digest of platform firmware following cryptographic best practices described in [3]. — Authenticity proof derived from data stored in platform persistent memory, fuses or hardware registers, such as but not limited to: — Identification of platform (see 8.3.1); — Authentication cryptographic key, symmetric or asymmetric following cryptographic best practices described in [3]; — Hardware unique fingerprint; — Collection of measurement of platform components, e.g. firmware hash, configuration setting. — Combination of above options e.g. in case modules or layers separately authenticated.
Anti-cloning	— At minimum, anti-replay protections mechanism, such as but not limited to: — Binding of the authenticity proof to a one-time, unpredictable parameter (e.g. in a challenge-response protocol, use of monotonic counter, timestamp, session ID, ephemeral keys, random number); — Use of a channel that inherently guarantees endpoint authenticity in a specific environment. — Optionally, confidentiality protection of the authenticity proof transmission, such as but not limited to: — Direct encryption of the authenticity proof following cryptographic best practices described in [3]; — Establishment of an encrypted communication channel, implemented according to cryptographic best practices described in [3], where communication may be intercepted but cannot be read; — Use of a channel that inherently guarantees endpoint confidentiality in a specific environment.

8.3.2.3 Applicability

The applicability of each aspect of this technical requirement is based on the platform risk assessment.

It is mandatory for platform falling into PTF-SER category that claims attestation of authenticity capability and/or protections against cloning or unauthorized replacement.

prEN 50766:2026 (E)

It is intended for platforms that are to be integrated into devices that:

- need to establish a trusted relationship with external entities, based on verified authenticity, and/or
- support the deployment of software in the field, where it is essential to verify the authenticity of the platform on which the software will run (e.g. confidential computing, Digital Right Management).

This is in particular the case where cloning or replacement could lead to safety issues (e.g. installation of counterfeit spare parts, impersonation allowing access to healthcare device), financial fraud (e.g. false payment terminals or cards/modules), or economic damage of a company or ecosystem with unsafe or poor quality counterfeit consumers accessories (e.g. printer cartridges, smartphone batteries and chargers, game consoles and accessories).

8.3.2.4 Assessment**8.3.2.4.1 Assessment preparation**

High level description of the how the authentication of platform technical requirement is implemented.

Platform implementation information in the form of description and/or source code and/or platform samples (representative of the product to be put on the market).

8.3.2.4.2 Assessment activities**8.3.2.4.3 Assessment objective****8.3.2.4.3.1 General**

The purpose of this assessment is to confirm the ability of the platform to generate a secure proof of authenticity, ensuring it is bound to the platform where applicable.

8.3.2.4.3.2 Input verification

The input verification for each aspect of the authentication of platform requirement relies on the activities outlined in Table 8 below.

Table 8 — TR_PAU input verification activities

Requirement aspects	Verification activities
Platform authenticity proof	Verify that the description of the authentication of platform implementation justifies how the platform can provide a proof of authenticity, in accordance with the defined implementation options. Verify in particular that potential cryptographic usage complies with best practices defined in [3].

8.3.2.4.3.3 Functional testing

The functional testing of each aspect of the authentication of platform requirement includes at minimum the testing steps outlined in Table 9 below.

Table 9 — TR_PAU functional testing activities

Requirement aspects	Verification steps
Platform authenticity proof	1. Execute the authenticity proof process, then: a. Verify that the output matches the expected authenticity proof and enables authentication of the platform.

8.3.2.4.3.4 Resistance testing

The resistance level is assessed by conducting analysis and/or testing to ensure that the platform authentication mechanism is protected against attacks, in accordance with instructions from 5.2.4.4.4 and based on the specific aspects described in following:

The base relevant attack scenarios are those targeting the integrity of the authentication of platform material where misrepresenting the platform authenticity proof had been identified as a risk.

EXAMPLE The availability of the platform is critical, altering the authenticity proof could falsely indicate unavailability and disrupt the final service.

If no such risk has been identified, the functionality is not required to be robust against attacks; only the presence of the feature, as assessed under functional testing, is necessary.

In addition, where authenticity demonstration is expected to be used for anti-cloning purposes, the relevant attack scenarios are those targeting at minimum the freshness of the authenticity proof, and optionally its confidentiality.

Such activities are expected to be applied across all relevant parts of the requirement implementation, including at minimum those listed in Table 10 below.

Table 10 — TR_PAU resistance testing activities

Requirement aspects	Target of test/analysis
Platform authenticity proof	- Exposed software and hardware interfaces related to authentication of platform feature; - Generation of authenticity proof; - Persistent storage of authenticity proof or related security parameter; - Runtime access to authenticity proof; - Handling of all security parameters, cryptographic (e.g. keys) or not (e.g. flags, configuration parameters, state information, permission information), associated with authenticity proof protection, at minimum during persistent storage, loading and storage in volatile memory, and active processing.
Anti-cloning	- Anti-replay mechanism; - When implemented, confidential transmission mechanism of authenticity proof; - Handling of all security parameters, cryptographic (e.g. keys) or not (e.g. flags, configuration parameters, state information, permission information), associated with anti-cloning protections, at minimum during persistent storage, loading and storage in volatile memory, and active processing.

8.3.2.4.4 Assessment verdict

The verdict is assigned as defined in 5.2.5.

8.3.2.4.5 Assessment evidence

Evidence as listed in 5.2.6.

8.3.3 TR_INI Secure initialisation support

8.3.3.1 Requirement

The platform shall ensure its integrity and authenticity during initialisation until it reaches the secure expected state or a failure state.

prEN 50766:2026 (E)

In the secure expected state the platform shall provide capabilities to dependent components running on the platform that enable their secure initialisation.

NOTE Secure expected state is entered when all assets are protected.

8.3.3.2 Implementation options

The secure initialization process shall be implemented using one of the options (black bullets) for each applicable requirement aspect specified in Table 11 below.

Table 11 — TR_INI implementation options

Requirement aspects	Implementation options
Platform firmware integrity and authenticity	— Cryptographic integrity and authenticity verification mechanisms following best practices described in [3]; — Platform firmware in read-only memory e.g. ROM, locked Flash; — Variant or alternative meeting the requirement; — Combination of above options.
Failure handling	— Reset of platform; — Transitioning to a predefined failure mode; — Combination of above options.
Dependent component support	— Cryptographic integrity and authenticity verifications mechanisms following best practices described in [3]; — Dependent component firmware in read-only memory e.g. ROM, locked Flash; — Variant or alternative meeting the requirement; — Combination of above options.

8.3.3.3 Applicability

This technical requirement is by default mandatory for PTF-COR platform category as it provides root protections for all platform assets (see Clause A.2).

However, the following exceptions apply:

Support to dependent component may be delegated to other components outside the scope of the platform, including the dependent component itself, provided this is explicitly stated in the platform security guidance (see 8.4.1). For platforms from category PTF-SER that claim cryptographic verifications mechanisms, the implementation by another component preferably relies on it.

The platform firmware integrity and/or authenticity aspects of the secure initialization may be technically infeasible (e.g. limited memory or CPU as in low-cost sensor nodes or battery-powered platforms, no or old cryptographic feature as in legacy platforms). In particular, implementing authenticity may demand resources not available.

If platform firmware integrity and/or authenticity cannot be implemented, the user shall be informed about the risks and/or the platform usage is expected to be limited to one of the following scenarios:

- The operational environment provides sufficient physical and/or logical protections to ensure the security of platform initialization aspects that are not handled by the platform;
- The platform lifetime is shorter than the minimal time for exploitation of attacks in scope of the applicable risk environment (e.g. disposable devices).

NOTE Information to be provided to the user about security functionality delegation and platform usage restriction is addressed in 8.4.1.

8.3.3.4 Assessments

8.3.3.4.1 Assessment objective

The purpose of this assessment is to confirm the ability of the platform to always initialize the expected firmware and/or software in the designated operational state.

8.3.3.4.2 Assessment preparation

High level description of the implementation of the platform secure initialization technical requirement.

Platform implementation information in the form of description and/or source code and/or platform samples (representative of the product to be put on the market).

8.3.3.4.3 Assessment activities

8.3.3.4.3.1 Input verification

The input verification for each aspect of the secure initialisation requirement relies on the activities outlined in Table 12 below.

Table 12 — TR_INI input verification activities

Requirement aspects	Verification activities
Platform firmware integrity and authenticity	Verify that the description of the platform security initialization implementation justifies how the platform integrity and authenticity are checked during initialization, and, if applicable, how multiple modes or states are supported, in accordance with the defined implementation options. Verify in particular that potential cryptographic usage complies with best practices defined in [3].
Failure handling	Verify that the description of the platform security initialization implementation justifies how the platform handles failure, in accordance with the defined implementation options.
Dependent component support	Verify that the description of the platform security initialization implementation justifies how the platform supports dependent component in ensuring their secure initialization, in accordance with the defined implementation options. Verify in particular that potential cryptographic usage complies with best practices defined in [3].

8.3.3.4.3.2 Functional testing

The functional testing of each aspect of the secure initialization requirement includes at minimum the testing steps outlined in Table 13 below.

Table 13 — TR_INI functional testing activities

Requirement aspects	Verification steps
Platform firmware integrity and authenticity Failure handling	For firmware (full or part of it) in platform internal read-only memory, the authenticity and integrity is inherently ensured by the memory immutable properties, therefore no testing is required to validate these attributes. For other implementation option: 1. Trigger platform initialisation under normal conditions, with a valid firmware, then: a. Verify that the platform reaches the expected operational state;

Requirement aspects	Verification steps
	i. If multiple states or modes are defined, verify that each is correctly reached when its access conditions are satisfied. 2. Trigger platform initialisation under fault conditions, with a non-valid firmware (e.g. wrong signature or modified firmware), then: a. Verify that the initialization fails; b. Verify that the platform transitions to the expected failure state; i. If multiple states or modes are defined, verify that only failure state can be reached.
Dependent component support Failure handling	For dependent component implementation (full or part of it) in platform internal read-only memory, the authenticity and integrity is inherently ensured by the memory immutable properties, therefore no testing is required to validate these attributes. For other implementation option: 1. Trigger dependent component initialisation under normal conditions, with a valid firmware, then: a. Verify that the platform reaches the expected operational state; i. If multiple states or modes are defined, verify that each is correctly reached when its access conditions are satisfied. 2. Trigger dependent component initialisation under fault conditions, with a non-valid firmware (e.g. wrong signature or modified firmware), then: a. Verify that the initialization fails; b. Verify that the platform transitions to the expected failure state; c. If multiple states or modes are defined, verify that only failure state can be reached.

8.3.3.4.3.3 Resistance testing

The resistance level is assessed by conducting analysis and/or testing to ensure that the platform initialisation process is protected against attacks, in accordance with instructions from 5.2.4.4.4 and based on the specific aspects described in following:

The relevant attack scenarios are those targeting the integrity and authenticity of the platform firmware, as well as the correct and reliable transition to the appropriate operational mode or state.

Such activities are expected to be applied across all relevant parts of the requirement implementation, including at minimum those listed in Table 14 below.

Table 14 — TR_INI resistance testing activities

Requirement aspects	Target of test/analysis
Platform firmware integrity and authenticity	— Integrity and authenticity verifications of the platform firmware; Note that in case of firmware in read-only memory, the authenticity and integrity is inherently ensured by the memory immutable properties, therefore no testing is required to validate these attributes; — Verification of access conditions associated with each operational mode or state, where such multiple configurations are supported;

Requirement aspects	Target of test/analysis
	- Exposed software and hardware interfaces available during initialization process; - Handling of all security parameters, cryptographic (e.g. keys) or not (e.g. flags, configuration parameters, state information, permission information), associated with protection of platform firmware, at minimum during persistent storage, loading and storage in volatile memory, and active processing.
Dependent component support	- Integrity and authenticity verification of the dependent component firmware; Note that in case of dependent component implementation in read-only memory, the authenticity and integrity is ensured by design and does not require specific testing. - Access conditions validation for each anticipated platform state, ensuring that transition to these states only occur when appropriate conditions are met (e.g. right privileges, dependent component life-cycle state); - Handling of all security parameters, cryptographic (e.g. keys) or not (e.g. flags, configuration parameters, state information, permission information), associated with protection of dependent component firmware, at minimum during persistent storage, loading and storage in volatile memory, and active processing.

8.3.3.4.4 Assessment verdict

The verdict is assigned as defined in 5.2.5.

8.3.3.4.5 Assessment evidence

Evidence as listed in 5.2.6.

8.3.4 TR_SUP Secure update of platform

8.3.4.1 Requirement

The platform shall support secure update of updatable parts.

The secure update mechanisms shall ensure the integrity and the authenticity of the updates.

The secure update mechanisms shall ensure that the version of the security update is newer compared to the current version.

In case of secure update failure, the platform shall enter a controlled state which ensures the continuous protection of the assets.

NOTE 1 This technical requirement can be associated with other technical requirements (for example secure communication, or access control to security services) to authenticate and/or control the update provider.

NOTE 2 Automaticity aspect of security update is not applicable to the platforms as this is based on interaction with the remote operational environment (e.g. cloud or edge server) done via an application which is the one able to implement automaticity and trigger the update service of the platform when required.

NOTE 3 Easy-to-use opt-out mechanism, notification and postponing option for user are not applicable to the platforms as they are only interfacing with dependent components and not directly to users.

8.3.4.2 Implementation options

The platform secure update process shall be implemented using one of the options (black bullets) for each applicable requirement aspect specified in Table 15 below.

783

Table 15 — TR_SUP implementation options

Requirement aspects	Implementation options
Integrity and authenticity of update package	— Cryptographic integrity and authenticity verification mechanisms following cryptographic best practices described in [3]; — Restriction of update process access to authorized users responsible for allowing — authentic and unmodified update package only, based on access control with same implementation options as defined in 8.3.8.2; combination with cryptographic verification mechanism in case of remote update. — Variant or alternative meeting the requirement; — Combination of above options.
Package newer version	— Reference version of the current firmware comparison with the version of the new firmware; — Restriction of access to update initiation to authenticated users permitting only validated versions; — Variant or alternative meeting the requirement.
Update failure handling	Failure handling implementation shall include each following sub-aspect: Sub-aspect - Termination of the update process after failure detection with one of these options: — Reset of platform; — Transitioning to a predefined failure or secure recovery mode; — Combination of above options. Sub-aspect - Preservation of the platform secure state with one of these options: — Atomic updates mechanism that writes update package into temporary memory, committing only upon successful validation or rolling back to previous version in case of failure; — Immutable bootloader with recovery mechanism in case it detects invalid firmware; — Memory partitions, with active firmware in one and candidate new firmware in the other one. Only when the candidate firmware is checked to be consistent, it becomes the active one; — Operations during the secure recovery mode; — Variant or alternative meeting the requirement.

784

8.3.4.3 Applicability

785

This technical requirement is by default mandatory for platform category PTR-COR as it provides capabilities to deploy security updates in response to vulnerabilities into the platform identified in the field.

786

787

However, all or part of the platform might not be updatable by design (e.g. hardware only, non-modifiable memory), in which case security mitigations shall be allowed by patching mechanisms, as long as technically feasible.

788

789

790

Where patching is technically infeasible (e.g. limited memory or CPU as in low-cost sensor nodes or battery-powered platforms, no or old cryptographic feature as in legacy platforms), the user shall be informed about the risks and/or the platform usage is expected to be restricted to one of the following scenarios:

791

792

793

- The platform is operated in environment providing the protections for the platform initialization;

794

- Compensating measures are implemented by external components (not under the control of the platform);

795 — The platform lifetime is shorter than the minimal time required to exploit attacks in scope of the platform
796 risk environment (e.g. disposable devices).

797 NOTE Information to be provided to the user about platform usage restriction is addressed in 8.4.1.

798 8.3.4.4 Assessment

799 8.3.4.4.1 Assessment objective

800 The purpose of this assessment is to confirm that security updates, and only expected ones, can be applied to
801 the platform.

802 8.3.4.4.2 Assessment preparation

803 High level description of the implementation of the platform secure update technical requirement.

804 Platform implementation information in the form of description and/or source code and/or platform samples
805 (representative of the product to be put on the market).

806 8.3.4.4.3 Assessment activities

807 8.3.4.4.3.1 Input verification

808 The input verification for each aspect of the platform secure update requirement relies on the activities outlined
809 in Table 16 below.

810 **Table 16 — TR_SUP input verification activities**

Requirement aspects	Verification activities
Integrity and authenticity of update package	Verify that the description of the platform secure update implementation justifies how the integrity and authenticity of the update package are ensured, in accordance with the defined implementation options. Verify in particular that potential cryptographic usage complies with best practices defined in [3].
Package newer version	Verify that the description of platform secure update implementation justifies how platform prevents updates with unauthorized or unexpected version, in accordance with the defined implementation options.
Update failure handling	Verify that the description of the secure update implementation justifies how failures occurring during secure update process are properly managed, in accordance with the defined implementation options.

811 8.3.4.4.3.2 Functional testing

812 The functional testing of each applicable aspect of the platform secure update requirement have been
813 implemented as described (see Assessment preparation). This includes at minimum the testing steps outlined
814 in Table 17 below.

815 **Table 17 — TR_SUP functional testing activities**

Requirement aspects	Verification steps
Integrity and authenticity of update package	1. Execute a platform update using a correct update package or fulfil the access conditions, then; a. Verify that the update process completes successfully; b. Verify that the update has been effectively applied. 2. Attempt to execute a platform update using an incorrect update package or not fulfilling the access conditions, then: a. Verify that the update process fails as expected;

prEN 50766:2026 (E)

Requirement aspects	Verification steps
	b. Verify that the platform transitions to the appropriate failure state; c. Verify that no changes have been applied as a result of the failed update.
Package newer version	1. Execute a platform update using a package with newer version than the currently installed version, then: a. Verify that the update process completes successfully; b. Verify that the update has been effectively applied. 2. Attempt to execute a platform update using a package with an older version than the currently installed version, then: a. Verify that the update process is rejected; b. Verify that the platform remains in its current version state; c. Verify that no changes have been applied as a result of the rejected update.
Update failure handling	Appropriate termination of the update process in case of failure handling is covered by observation of failure in other aspects assessment. For the maintenance of the platform secure state after failure detection: 1. Initiate a platform update process and intentionally trigger a failure, then: a. Verify that the platform reaches the expected secure state; b. Verify that no unexpected update-related changes have been processed.

8.3.4.4.3.3 Resistance testing

The resistance level is assessed by conducting analysis and/or testing to ensure that the platform update process is protected against attacks, in accordance with instructions from 5.2.4.4.4 and based on the specific aspects described in following:

The relevant attack scenarios are those targeting the integrity, authenticity and appropriate version of the platform update package.

Such activities are expected to be applied across all relevant parts of the requirement implementation, including at minimum those listed in Table 18 below.

Table 18 — TR_SUP resistance testing activities

Requirement aspects	Target of test/analysis
Integrity and authenticity of update package	— Exposed software and hardware interfaces related to secure update feature; — Cryptographic verification of the platform update package or related resistance testing targets of 8.3.8.4.3.3 apply. — Handling of all security parameters, cryptographic (e.g. keys) or not (e.g. flags, configuration parameters, state information, permission information), associated with protection of platform update package, at minimum during persistent storage, loading and storage in volatile memory, and active processing.
Package newer version	— Verification of the version.
Update failure handling	— Failure handling overall process.

8.3.4.4.4 Assessment verdict

The verdict is assigned as defined in 5.2.5.

8.3.4.4.5 Assessment evidence

Evidence as listed in 5.2.6.

8.3.5 TR_SUD Secure update of dependent components

8.3.5.1 Requirement

The platform shall provide the capability to the dependent components to ensure its secure update.

NOTE 1 Automaticity aspect of security update is not applicable to the platform as this is based on interaction with the remote operational environment (e.g. cloud or edge server) done via an application which is the one able to implement automaticity and trigger the update service of the platform when required.

NOTE 2 Easy-to-use opt-out mechanism, notification and postponing option for user are not applicable to the platforms as they are only interfacing with the dependent components and not directly to users.

8.3.5.2 Implementation options

The dependent component secure update process shall be implemented using one of the options (black bullets) specified in Table 19 below.

Table 19 — TR_SUD implementation options

Requirement aspects	Implementation options
Support of dependent component update	— Cryptographic verifications on update package by the platform itself following cryptographic best practices described in [3]; — Restriction of update process access to authorized users responsible for allowing only authentic and unmodified update package only, based on access control with same implementation options as defined in 8.3.8.2; combination with cryptographic verification mechanism in case of remote update. — Variant or alternative meeting the requirement; — Combination of above options.

8.3.5.3 Applicability

This technical requirement is by default mandatory for PTF-COR platform category, in case dependent components are to be run on the platform, as it provides capabilities to deploy security updates in response to vulnerabilities into the dependent component identified in the field.

However, this technical requirement may be delegated to other components outside the scope of the platform, including the dependent component itself, provided this is explicitly stated in the security guidance of the platform (see 8.4.1). For platforms from category PTF-SER that claim secure cryptographic signature verification, the implementation by another component preferably relies on it.

NOTE Information to be provided to the user about security functionality delegation is addressed in 8.4.1.

8.3.5.4 Assessment

8.3.5.4.1 Assessment objective

The purpose of this assessment is to confirm the ability of the platform to support the secure update of the dependent component.

prEN 50766:2026 (E)

8.3.5.4.2 Assessment preparation

High level description of the implementation of the dependent component secure update technical requirement. Platform implementation information in the form of description and/or source code and/or platform samples (representative of the product to be put on the market).

8.3.5.4.3 Assessment activities

8.3.5.4.3.1 Input verification

The input verification for each aspect of the dependent component secure update requirement relies on the activities outlined in Table 20 below.

Table 20 — TR_SUD input verification activities

Requirement aspects	Verification activities
Support of dependent component update	Verify that the description of the dependent component secure update implementation justifies how the platform support the secure update of the dependent component, in accordance with the defined implementation options. Verify in particular that potential cryptographic usage complies with best practices defined in [3].

8.3.5.4.3.2 Functional testing

The functional testing of each aspect of the dependent component secure update requirement includes at minimum the testing steps outlined in Table 21 below.

Table 21 — TR_SUD functional testing activities

Requirement aspects	Verification steps
Support of dependent component update	1. Execute a dependent component update using a correctly signed update package, then: a. Verify that the update process completes successfully; b. Verify that the update has been effectively applied; 2. Attempt to execute a dependent component update using a incorrectly signed update package, then a. Verify that the update process fails as expected; b. Verify that the platform transitions to the appropriate failure state; c. Verify that no changes have been applied as a result of the failed update.

8.3.5.4.3.3 Resistance testing

The resistance level is assessed by conducting analysis and/or testing to ensure that the dependent component secure update process is protected against attacks, in accordance with instructions from 5.2.4.4.4 and based on the specific aspects described in following.

The relevant attack scenarios are those targeting the integrity and authenticity of the dependent component update package.

Such activities are expected to be applied across all relevant parts of the requirement implementation, including at minimum those listed in Table 22 below.

875

Table 22 — TR_SUD resistance testing activities

Requirement aspects	Target of test/analysis
Support of dependent component update	- Exposed software and hardware interfaces related to update support feature; - Cryptographic verification of the platform update package or related resistance testing targets of 8.3.8.4.3.3 apply. - Handling of all security parameters, cryptographic (e.g. keys) or not (e.g. flags, configuration parameters, state information, permission information), that could compromise the authenticity proof across all relevant phases including at minimum persistent storage, loading and storage in volatile memory, and active processing.

876 **8.3.5.4.4 Assessment verdict**

877 The verdict is assigned as defined in 5.2.5.

878 **8.3.5.4.5 Assessment evidence**

879 Evidence as listed in 5.2.6.

880 **8.3.6 TR_ERA Secure erasure of data**881 **8.3.6.1 Requirement**

882 The platform shall implement a functionality to make selected data unavailable permanently.

883 **8.3.6.2 Implementation options**

884 The secure erasure of data feature can be activated through one or both of the following methods:

- 885 — Direct invocation of a dedicated interface that allows authorized entities to explicitly initiate the secure
886 erasure of data process.
- 887 — Automatic initiation of the erasing process at the triggering of a predefined event or condition (e.g.
888 decommissioning, tampering detection).

889 In both cases, the permanent unavailability of the data shall be implemented with one of the options (black
890 bullets) listed in Table 23 below.

891

Table 23 — TR_ERA implementation options

Requirement aspects	Implementation options
Unavailability of data	- Erasing of memory content method, with optional measures based on the memory technology, overall platform security architecture or data sensitivity, such as but not limited to: - single or multiple overwrites using random numbers or fix value for persistent memory; - power cycling for volatile memory. - For encrypted/scrambled data, erasing (see above) the encryption/scrambling keys (key shredding); - For volatile memory, periodically erasing (see above) part of the memory dedicated to sensitive data; - Programming One Time Programmable (OTP) bits in such a way to have the sensitive data inaccessible; - Variant or alternative meeting the requirement; - Combination of options above.

8.3.6.3 Applicability

This technical requirement is by default mandatory for platform category PTF-COR that handles confidential data.

However, exception applies for confidential data that cannot be erased for technical constraints (e.g. memory immutability); in such cases, the user shall be informed about the risks and/or the platform usage is expected to be limited to one of the following scenarios:

- The platform is operated in environments providing adequate protections against memory dumping.
- Compensating measures are implemented by external components (not under the control of the platform).

NOTE 1 User data involving privacy concerns cannot be stored in immutable memory and remain erasable.

NOTE 2 Information to be provided to the user about platform usage restriction is addressed in 8.4.1.

8.3.6.4 Assessment**8.3.6.4.1 Assessment objective**

The purpose of this assessment is to confirm the ability of the platform to persistently remove the access to all designated data when required.

8.3.6.4.2 Assessment preparation

High level description of the implementation of the secure data erase technical requirement.

Platform implementation information in the form of description and/or source code and/or platform samples (representative of the product to be put on the market).

8.3.6.4.3 Assessment activities**8.3.6.4.3.1 Input verification**

The input verification for each aspect of the secure erasure of data requirement relies on the activities outlined in Table 24 below.

Table 24 — TR_ERA input verification activities

Requirement aspects	Verification activities
Unavailability of data	Verify that the description of the secure erasure of data implementation justifies how data are permanently made unavailable from platform memory, in accordance with the defined implementation options.

8.3.6.4.3.2 Functional testing

The functional testing of each aspect of the secure erasure of data requirement includes at minimum the testing steps outlined in Table 25 below.

Table 25 — TR_ERA functional testing activities

Requirement aspects	Verification steps
Unavailability of data	1. Initiate the secure erasure of data process either by directly invoking the designated interface or by triggering a corresponding event, then: a. Verify that the data are not available anymore.

8.3.6.4.3.3 Resistance testing

The resistance level is assessed by conducting analysis and/or testing to ensure that the secure erasing mechanism is protected against attacks, in accordance with instructions from 5.2.4.4.4 and based on the specific aspects described in following:

The relevant attack scenarios are those targeting the confidentiality of data via the bypass of the secure erasure functionality.

Such activities are expected to be applied across all relevant parts of the requirement implementation, including at minimum those listed in Table 26 below.

Table 26 — TR_ERA resistance testing activities

Requirement aspects	Target of test/analysis
Unavailability of data	- Exposed software and hardware interfaces related to secure erasure; - Erasure process.

8.3.6.4.4 Assessment verdict

The verdict is assigned as defined in 5.2.5.

8.3.6.4.5 Assessment evidence

Evidence as listed in 5.2.6.

8.3.7 TR_ISO Isolation mechanisms

8.3.7.1 Requirement

The platform shall implement isolation mechanisms when it is in operation to enforce any necessary separation of different parts of the platform and/or between the platform and the dependent components and/or within the dependent components.

NOTE Isolation ensures that different parts of the platform and/or dependent components cannot interfere with one another

8.3.7.2 Implementation options

Each applicable isolation mechanism shall be implemented using one of the options (black bullets) specified in Table 27 below.

Table 27 — TR_ISO implementation options

Requirement aspects	Implementation options
Isolation between entities (platform, platform parts, dependent components)	- Spatial separation mechanism, such as but not limited to: - Memory Protection Unit (MPU) defining distinct memory regions for each entity to be isolated; - Memory Management Unit (MMU) defining distinct virtual memory spaces for each entity to be isolated; - Hardware firewalls/bus masters regulating access to resources; - Solutions managing distinct execution domains (e.g. secure and non-secure). - Physical separation mechanism, such as but not limited to: - Distinct hardware resources dedicated to each entity to be isolated (e.g. dedicated cores and memory spaces, co-

Requirement aspects	Implementation options
	processor, secure element, hardware security module, secure enclave). — Privilege / Execution mode separation mechanism, such as but not limited to: — Privilege rings or modes where entities runs either in privileged or unprivileged mode; — Hypervisors creating virtual environments. — Temporal isolation where only one entity execute at a given time; — Logical separation using software mechanisms to define domains and manage the controlled sharing of hardware resources, and communications between them; — Variant or alternative meeting the requirement; — Combinations of above options.

8.3.7.3 Applicability

This technical requirement applicability is determined based on the platform risk assessment.

The isolation of the platform from dependent components is mandatory for platforms of category PTF-COR, except if the logical environment is explicitly designated as trusted (ENV-TRL).

NOTE Information of the user about platform environment restriction is addressed in 8.4.1.

The isolation between parts of the platform is mandatory for platforms of category PTF-ADV that claim the management of varying security levels of execution for internal security functions, based on criteria such as criticality. It is intended for platforms that are to be integrated into devices that requires different security levels across their own services built upon the platform security features.

The isolation between the resources dedicated to each dependent component is mandatory for platforms of category PTF-ADV that claim the secure management of the execution of several applications or processes. It is intended for platforms that are to be integrated into devices that support multiple isolated set of resources that need to be mutually protected.

8.3.7.4 Assessment

8.3.7.4.1 Assessment objective

The purpose of this assessment is to confirm that the required isolation between platform components is effectively enforced.

8.3.7.4.2 Assessment preparation

High level description of the implementation of the isolation mechanisms technical requirement.

Platform implementation information in the form of description and/or source code and/or platform samples (representative of the product to be put on the market), including the configuration settings related to the isolation,

8.3.7.4.3 Assessment activities

8.3.7.4.3.1 Input verification

The input verification for each applicable aspect of the isolation mechanisms requirement relies on the activities outlined in Table 28 below.

969

Table 28 — TR_ISO input verification activities

Requirement aspects	Verification activities
Isolation between entities (platform, platform parts, dependent components)	Verify that the description of the isolation mechanisms implementation justifies how effective separation between the targeted entities is achieved, in accordance with the defined implementation options. Verify in particular that potential cryptographic usage complies with best practices defined in [3].

970 **8.3.7.4.3.2 Functional testing**

971 The functional testing of each applicable aspect of the isolation mechanisms requirement have been
 972 implemented as described (see Assessment preparation). This includes at minimum the testing steps outlined
 973 in Table 29 below.

974

Table 29 — TR_ISO functional testing activities

Requirement aspects	Verification steps
Isolation between entities (platform, platform parts, dependent components)	— Verify isolation configuration settings (e.g. MPU regions and permissions settings, firewall settings) are well designed and properly implemented; — Attempt to access authorized resources, configuration settings or data from an entity to another isolated one, then: — Verify that access is granted. — Attempt to access not authorized resources, configuration settings or data from an entity to another isolated one, then: — Verify that access is rejected or ignored; — Verify that only authorized operations or data manipulation are possible. — Trigger communications between the isolated entities, then: — Verify that only authorized and explicitly defined interactions occur.

975 **8.3.7.4.3.3 Resistance testing**

976 The resistance level is assessed by conducting analysis and/or testing to ensure that the applicable isolation
 977 mechanisms are protected against attacks, in accordance with instructions from 5.2.4.4.4 and based on the
 978 specific aspects described in following.

979 The relevant attack scenarios are those targeting the confidentiality and integrity of data, and access to security
 980 functionalities.

981 Such activities are expected to be applied across all relevant parts of the requirement implementation, including
 982 at minimum those listed in Table 30 below.

983

Table 30 — TR_ISO resistance testing activities

Requirement aspects	Target of test/analysis
Isolation between entities (platform, platform parts, dependent components)	— Exposed software and hardware interfaces crossing isolation boundaries (e.g. syscalls, IO, RPCs, file formats); — Isolation configuration settings (e.g. domains/regions definitions, permissions attributions) management (storage, access, verifications, and where applicable dynamic reconfigurations); — Resources allocation and usage (e.g. memory, stack/heap, CPU, peripherals); — Failure management;

Requirement aspects	Target of test/analysis
	— Handling of all security parameters, cryptographic (e.g. keys) or not (e.g. flags, configuration parameters, state information, permission information), associated with isolation features, at minimum during persistent storage, loading and storage in volatile memory, and active processing.

8.3.7.4.4 Assessment verdict

The verdict is assigned as defined in 5.2.5.

8.3.7.4.5 Assessment evidence

Evidence as listed in 5.2.6.

8.3.8 TR_ACC Access control to security functionalities

8.3.8.1 Requirement

The platform shall implement mechanisms enabling access control to be provided to security functionalities requiring it.

8.3.8.2 Implementation options

The access control to security functionalities process shall be implemented using one of the options (black bullets) specified in Table 31 below.

Table 31 — TR_ACC implementation options

Requirement aspects	Implementation options
Access control granting	— User authentication, such as but not limited to: — Cryptographic authentication based on mechanisms following best practices defined in [3]; — Authentication based on password following best practices in [4], [5], [6], [7]; — Possession of a token. NOTE The exchange of the authenticity proof can be protected by secure communication with same implementation options as in 8.3.10.2. — Verification of element of context, such as but not limited to: — Possession of capability (e.g. metadata interpreted by hardware); — Privileged user (e.g. "root"), groups, firmware/software; — Register or bit values. — Physical proximity proof, such as but not limited to: — Access via specific port/interface; — User consent for human users (e.g. push button, sequence of user inputs, physical presence in protected environment). — Variant or alternative meeting the requirement; — Combination of above options.

8.3.8.3 Applicability

This technical requirement applicability is determined based on the platform risk assessment.

It is mandatory for platforms of category PTF-ADV that claim to provide access control to its security features.

999 It is intended for platforms that are to be integrated into devices that require user(s)/role(s) handling for access
1000 to the platform security features.

1001 **EXAMPLE 1** An administrator should be able to configure platform settings while regular users cannot.

1002 **EXAMPLE 2** An application has access to the platform secure cryptographic features, which should not be available to
1003 other applications.

1004 **8.3.8.4 Assessment**

1005 **8.3.8.4.1 Assessment objective**

1006 The purpose of this assessment is to confirm that the required access controls to the platform security
1007 functionalities are efficiently enforced.

1008 **8.3.8.4.2 Assessment preparation**

1009 High level description of the implementation of the access control to security functionalities technical
1010 requirement.

1011 Platform implementation information in the form of description and/or source code and/or platform samples
1012 (representative of the product to be put on the market).

1013 **8.3.8.4.3 Assessment activities**

1014 **8.3.8.4.3.1 Input verification**

1015 The input verification for each applicable aspect of the access control requirement relies on the activities outlined
1016 in Table 32 below.

1017 **Table 32 — TR_ACC input verification activities**

Requirement aspects	Verification activities
Access control granting	Verify that the description of the access control implementation justifies how the access to security functionalities are effectively restricted, in accordance with the defined implementation options. Verify in particular that potential cryptographic usage complies with best practices defined in [3].

1018 **8.3.8.4.3.2 Functional testing**

1019 The functional testing of each applicable aspect of the access control to security functionalities requirement
1020 includes at minimum the testing steps outlined in Table 33 below.

1021 **Table 33 — TR_ACC functional testing activities**

Requirement aspects	Verification steps
Access control granting	— Verify that the authorization mapping between identifies/roles and permissions is correct; — Invoke each restricted security functionalities with the appropriate access rights, then: — Verify that the access is granted. — Invoke each restricted security functionalities without the appropriate access rights, then: — Verify that the access is not granted and that the security functionality is not executed.

prEN 50766:2026 (E)**8.3.8.4.3.3 Resistance testing**

The resistance level is assessed by conducting analysis and/or testing to ensure that the access control mechanism is protected against attacks, in accordance with instructions from 5.2.4.4.4 and based on the specific aspects described in following:

The relevant attack scenarios are those targeting the access permissions to security functionalities, resulting in the compromise and/or corruption of sensitive data.

Such activities are expected to be applied across all relevant parts of the requirement implementation, including at minimum those listed in Table 34 below.

Table 34 — TR_ACC resistance testing activities

Requirement aspects	Target of test/analysis
Access control granting	— Exposed software and hardware interfaces restricted by access control; — Authorizations mapping management (storage, access, verifications, and where applicable dynamic reconfigurations); — Authentication verification (e.g. signature verification); — Access decisions, granting and denying; — Persistent storage of authentication credentials; — Runtime access to authentication credentials; — Handling of all security parameters, cryptographic (e.g. keys) or not (e.g. flags, configuration parameters, state information, permission information), associated with access control and authentication material, at minimum during persistent storage, loading and storage in volatile memory, and active processing.

8.3.8.4.4 Assessment verdict

The verdict is assigned as defined in 5.2.5.

8.3.8.4.5 Assessment evidence

Evidence as listed in 5.2.6.

8.3.9 TR_STO Secure storage**8.3.9.1 Requirement**

The platform shall implement a functionality for the dependent components to store user data in non-volatile memory that preserves their confidentiality and/or integrity and/or authenticity.

NOTE Confidentiality, integrity and authenticity of user data in volatile memory are enforced by physical protections and isolation mechanisms.

8.3.9.2 Implementation options

When the secure storage feature supports only a single user/role, and the platform operates within trusted physical and logical environments (ENV-TRP and ENV-TRL), confidentiality, integrity and authenticity can be ensured only through tamper-resistance protections of 8.3.15.

In any other case, the secure storage feature shall be implemented using the options (black bullets) for each applicable requirement aspect as specified in Table 35 below.

1047

Table 35 — TR_STO implementation options

Requirement aspects	Implementation options
Persistent storage	— Storage in persistent memory of the platform itself, or externally within containers (also commonly referred as objects, blobs, or wrappers in context of encryption).
Confidentiality	— At minimum, restriction of storage content reading access to authorized entities only based on access control with same implementation options as defined in 8.3.8.2; — Optionally, additional measures such as but not limited to: — Encryption of storage content following cryptographic best practices described in [3]; — Obfuscation of storage content; — Scrambling; — Data fragmentation. In addition, when storage resides in persistent memory outside of the platform control encryption is mandatory.
Integrity	— At minimum, restriction of storage content writing access to authorized entities only based on access control with same implementation options as defined in 8.3.8.2, — Optionally, additionally measures, such as but not limited to: — Cryptographic integrity protections following best practices described in [3]; — Redundancy of part of the storage; — 1 correcting code. In addition, when storage resides in persistent memory outside of the platform control: — Versioning of the storage container preventing rollback of previous content (reference version being stored internally to the platform).
Authenticity	— At minimum, restriction of storage content writing access to authorized entities only based on access control with same implementation options as defined in 8.3.8.2; — Optionally, additional measures, such as but not limited to: — Owner-to-data binding information. In addition, when storage resides in persistent memory outside of the platform control: — Generation of platform-to-data binding information to prevent the replacement of a container by a legitimate container from another platform.

1048 8.3.9.3 Applicability

1049 The applicability of each aspect of this technical requirement is determined based on the platform risk
1050 assessment.

1051 It is mandatory for platforms of category PTF-SER that claim to offer secure storage feature for user assets.

1052 If external storage is used and the platform cannot manage integrity and/or authenticity versioning, or platform-
1053 to-data binding, its usage is expected to be limited to one of the following scenarios:

1054 — The platform is operated in environment providing adequate protections against memory dumping;

1055 — Compensating measures are implemented by external components (not under the control of the platform).

prEN 50766:2026 (E)

It is intended for platforms that are to be integrated into devices that use the platform to store their own assets. Confidentiality, integrity and authenticity depend on the security properties determined during risk assessment of the integrating product.

8.3.9.4 Assessment**8.3.9.4.1 Assessment objective**

The purpose of this assessment is to confirm that the secure storage feature protects the associated stored data in accordance with their defined security properties.

8.3.9.4.2 Assessment preparation

High level description of the implementation of the secure storage technical requirement.

Platform implementation information in the form of description and/or source code and/or platform samples (representative of the product to be put on the market).

8.3.9.4.3 Assessment activities**8.3.9.4.3.1 Input verification**

The input verification for each applicable aspect of the secure storage requirement relies on the activities outlined in Table 36 below.

Table 36 — TR_STO input verification activities

Requirement aspects	Verification activities
Persistent storage	Verify that the description of the secure storage implementation justifies how and where data are stored, in accordance with the defined implementation options.
Confidentiality	Verify that the description of the secure storage implementation justifies how the confidentiality of the data are ensured, in accordance with the defined implementation options. Verify in particular that potential cryptographic usage complies with best practices defined in [3]. In addition, if confidentiality is based on access control, related input verification of 8.3.8.4.3 apply.
Integrity	Verify that the description of the secure storage implementation justifies how the integrity of the data are ensured, in accordance with the defined implementation options. Verify in particular that cryptographic usage complies with best practices defined in [3]. In addition, if integrity is based on access control, related input verification of 8.3.8.4.3 apply.
Authenticity	Verify that the description of the secure storage implementation justifies how the authenticity of the data are ensured, in accordance with the defined implementation options. Verify in particular that potential cryptographic usage complies with best practices defined in [3]. In addition, if authenticity is based on access control, related input verification of 8.3.8.4.3 apply.

8.3.9.4.3.2 Functional testing

The functional testing of each applicable aspect of the secure storage requirement includes at minimum the testing steps outlined in Table 37 below.

1075

Table 37 — TR_STO functional testing activities

Requirement aspects	Verification steps
Persistent storage	- Store data by using the platform secure storage feature; Attempt to retrieve the stored data across resets cycles using the platform secure storage interface, then: - Verify that the data are successfully retrieved.
Confidentiality	Related functional testing verifications of 8.3.8.4.3.2 apply. In addition, when storage resides in persistent memory outside of the platform control: - Identify the external data storage, then: - Verify that the container is encrypted as specified.
Integrity	Related functional testing verifications of 8.3.8.4.3.2 apply. In addition, when storage resides in persistent memory outside of the platform control: - Identify the external data storage; Modify the storage content; Attempt to retrieve the stored data using the platform secure storage interface, then: - Verify that the attempt fails and no data are retrieved. In addition, when storage resides in persistent memory outside of the platform control: - Identify the external data storage; Copy and save the storage content; Update stored data using the platform secure storage feature; Overwrite the external storage with previous saved content; Attempt to retrieve the stored data using the platform secure storage interface, then: - Verify that the attempt fails and no data are retrieved.
Authenticity	Related functional testing verifications of 8.3.8.4.3.2 apply. If authenticity is based on the association between data and owner identification: - Store data by using the platform secure storage interface; Retrieve data by using the platform secure storage interface; - Verify that the data are retrieved successfully along with the data owner identity/authenticity proof; - Verify that the user/role authenticity proof is correct. In addition, when storage resides in persistent memory outside of the platform control: - On a first platform, store data once, do not update, identify the external data storage and copy and save the storage content; On a second platform, store data once, do not update, identify the external data storage; Overwrite the external storage on second platform with saved content from first platform, then: - Verify that the feature fails and no data are retrieved.

prEN 50766:2026 (E)**8.3.9.4.3.3 Resistance testing**

The resistance level is assessed by conducting analysis and/or testing to ensure that the secure storage mechanism is protected against attacks, in accordance with instructions from 5.2.4.4.4 and based on the specific aspects described in following:

The relevant attack scenarios are those targeting the security properties of the sensitive data in the designated secure storage.

Such activities are expected to be applied across all relevant parts of the requirement implementation, including at minimum those listed in Table 38 below.

Table 38 — TR_STO resistance testing activities

Requirement aspects	Target of test/analysis
Persistent storage	— Exposed software and hardware interfaces related to secure storage feature.
Confidentiality	— Related resistance testing targets of 8.3.8.4.3.3 apply. In addition, when storage resides in persistent memory outside of the platform control, encryption operation.
Integrity	— Related resistance testing targets of 8.3.8.4.3.3 apply; — Setting of the integrity proof; — Verification of the integrity proof. — Handling of all security parameters, cryptographic (e.g. keys) or not (e.g. flags, configuration parameters, state information, permission information), associated with integrity proof protection, at minimum during persistent storage, loading and storage in volatile memory, and active processing. In addition, when storage resides in persistent memory outside of the platform control: — Setting of the version of storage container; — Verification of the version of storage container.
Authenticity	— If authenticity is based on access control, related resistance testing targets of 8.3.8.4.3.3 apply; — Setting of the data owner authenticity proof; — Verification of the data owner authenticity proof; — Handling of all security parameters, cryptographic (e.g. keys) or not (e.g. flags, configuration parameters, state information, permission information), associated with authenticity proof protection, at minimum during persistent storage, loading and storage in volatile memory, and active processing. In addition, when storage resides in persistent memory outside of the platform control: — Setting of the platform-to-data binding information; — Verification of the platform-to-data binding information.

8.3.9.4.4 Assessment verdict

The verdict is assigned as defined in 5.2.5.

8.3.9.4.5 Assessment evidence

Evidence as listed in 5.2.6.

8.3.10 TR_COM Secure communications

8.3.10.1 Requirement

The platform shall implement a functionality ensuring the confidentiality and/or integrity and/or authenticity of selected data during communications.

8.3.10.2 Implementation options

The secure communication feature can be activated through one or both of the following methods:

- Direct invocation of a dedicated interface that allows authorized entities to explicitly initiate the secure communications of data outside of the platform.
- Automatic initiation of the secure communication feature at the triggering of a predefined event or condition (e.g. execution of remote data processing).

In both cases, the secure communication feature shall be implemented using one of the options (black bullets) for each applicable requirement aspect specified in Table 39 below.

Table 39 — TR_COM implementation options

Requirement aspects	Implementation options
Channel establishment	— Implementation of a communication protocol that ensure the transmission of sensitive data among endpoints.
Confidentiality	— Establishment of an encrypted communication channel, implemented according to cryptographic best practices described in [3]; — Establishment of a secure communication channel ensuring confidentiality protections over a trusted path (e.g. physical connection to an external component, physical layer properties); — Encryption of data communicated over non-secure channel implemented according to cryptographic best practices described in [3]; — Variant or alternative meeting the requirement.
Integrity	— Establishment of a communication channel implementing integrity protections according to cryptographic best practices described in [3]; — Establishment of a secure communication channel ensuring integrity protections over a trusted path (e.g. physical connection to an external component, physical layer properties); — Integrity protections of data to be sent over a non-secure channel implemented according to cryptographic best practices described in [3]; — Variant or alternative meeting the requirement.
Authenticity	— Establishment of a communication channel that ensures either single or mutual authentication protections of endpoints, based on security need, and in accordance with cryptographic best practices described in [3]; — Establishment of a secure communication channel ensuring either single or mutual authentication protections over a trusted path (e.g. physical connection to an external component, physical layer properties);

Requirement aspects	Implementation options
	— Authenticity protections of data to be sent over a non-secure channel implemented according to cryptographic best practices described in [3]; — Variant or alternative meeting the requirement.

8.3.10.3 Applicability

The applicability of each aspect of this technical requirement is determined based on the platform risk assessment.

It is mandatory for platforms of category PTF-SER that claim the capability to ensure the secure communications of sensitive data, including in scenarios involving remote data processing.

When processing data remotely, all aspects of the requirement are mandatory. In other scenarios, their applicability depends on the security properties of the data being transmitted over the channel.

Where such sensitive data include user data, it is intended for platforms that are to be integrated into devices that exchange sensitive data, such as personal data, financial details, authentication credentials, and similar types of sensitive content.

8.3.10.4 Assessment

8.3.10.4.1 Assessment objective

The purpose of this assessment is to confirm that the secure communication feature protects the associated transferred data in accordance with their defined security properties.

8.3.10.4.2 Assessment preparation

High level description of the implementation of the secure communication technical requirement.

Platform implementation information in the form of description and/or source code and/or platform samples (representative of the product to be put on the market).

8.3.10.4.3 Assessment activities

8.3.10.4.3.1 Input verification

The input verification for each aspect of the secure communication requirement relies on the activities outlined in Table 40 below.

Table 40 — TR_COM input verification activities

Requirement aspects	Verification activities
Communication channel establishment	Verify that the description of the secure communication implementation justifies how the platform exchanges sensitive data with external entities, in accordance with the defined implementation options.
Confidentiality	Verify that the description of the secure communication implementation justifies how the confidentiality of the data are ensured, in accordance with the defined implementation options. Verify in particular that potential cryptographic usage complies with best practices defined in [3].
Integrity	Verify that the description of the secure communication implementation justifies how the integrity of the data are ensured, in accordance with the defined implementation options. Verify in particular that potential cryptographic usage complies with best practices defined in [3].

Requirement aspects	Verification activities
Authenticity	Verify that the description of the secure communication implementation justifies how the authenticity of the endpoints is ensured, in accordance with the defined implementation options. Verify in particular that potential cryptographic usage complies with best practices defined in [3].

1125 8.3.10.4.3.2 Functional testing

1126 The functional testing of each aspect of the secure communication requirement includes at minimum the testing
 1127 steps outlined in Table 41 below.

1128 **Table 41 — TR_COM functional testing activities**

Requirement aspects	Verification steps
Communication channel establishment	1. Initiate a communication (based on the implementation option) with a test endpoint using the platform secure communication feature; a. If applicable, verify that channel parameters or configurations are as expected; Send data through this communication channel, then: b. Verify that the platform response matches expected, confirming that the data was properly received.
Confidentiality	For implementation of a communication based on encryption: 1. Initiate the secure communication with the platform from a test endpoint as described previously, then: a. Verify that data in the platform response are encrypted; b. Verify the decryption of data are successful. For implementation based on trusted path, no functional test is required.
Integrity	For implementation of a communication with cryptographic integrity protection: 1. Initiate the secure communication with the platform from a test endpoint as described previously; Perform legitimate data exchanges, then: a. Verify that the platform response includes the integrity proof; b. Verify the integrity proof is correct. 2. Initiate the secure communication with the platform from a test endpoint as described previously; Perform legitimate data exchanges; From the test endpoint, send communication packet with wrong integrity proof, then: a. Verify that subsequent platform response only includes expected data. b. Verify that the platform close the communication channel. 3. Initiate the secure communication with the platform from a test endpoint as described previously; Perform legitimate data exchanges; From the test endpoint, resend previously exchanged communication packages to the platform, then: a. Verify that subsequent platform response only include expected data.

Requirement aspects	Verification steps
	b. Verify that the platform close the communication channel. For implementation based on trusted path, no functional test is required.
Authenticity	For implementation of a communication with cryptographic authenticity protection: 1. Initiate the secure communication with the platform from a test endpoint as described previously; Perform legitimate data exchanges, then: a. Verify that the platform response includes the authenticity proof; b. Verify the authenticity proof is correct. 2. Initiate the secure communication with the platform from a test endpoint as described previously; Perform some legitimate data exchanges; From the test endpoint, send communication packet with wrong authenticity proof, then: a. Verify that subsequent platform response only include expected data. b. Verify that the platform close the communication channel. For implementation based on trusted path, no functional test is required.

8.3.10.4.3 Resistance testing

The resistance level is assessed by conducting analysis and/or testing to ensure that the secure communication feature is protected against attacks, in accordance with instructions from 5.2.4.4 and based on the specific aspects described in following:

The relevant attack scenarios are those targeting the security properties of the data exchanged via the designed secure communications.

Such activities are expected to be applied across all relevant parts of the requirement implementation, including at minimum those listed in Table 42 below.

Table 42 — TR_COM resistance testing activities

Requirement aspects	Target of test/analysis
Communication channel establishment Confidentiality Integrity Authenticity	— Exposed software and hardware interfaces related to secure communication feature. — Handling of all security parameters, cryptographic (e.g. keys) or not (e.g. flags, configuration parameters, state information, permission information), associated with secure channel protections, at minimum during persistent storage, loading and storage in volatile memory, and active processing.

8.3.10.4.4 Assessment verdict

The verdict is assigned as defined in 5.2.5.

8.3.10.4.5 Assessment evidence

Evidence as listed in 5.2.6.

8.3.11 TR_CRY Secure cryptographic features

8.3.11.1 Requirement

The platform shall implement cryptographic functionalities for dependent components following the principles of best practices for cryptography.

NOTE Examples of cryptographic functionalities are cryptographic operations (e.g. encryption, signing), random number generation, cryptographic key generation, key storage.

8.3.11.2 Implementation options

The secure cryptographic feature shall be implemented using the option specified in Table 43 below.

Table 43 — TR_CRY implementation options

Requirement aspects	Implementation options
Best practices	— Implementation of cryptographic algorithms in compliance with best practices specified in [3].

8.3.11.3 Applicability

This technical requirement applicability is determined based on the platform risk assessment.

It is mandatory for platforms of category PTF-SER that claim to offer cryptographic features that adhere to industry best practices.

It is intended for platforms that are to be integrated into devices that require a cryptographic foundation to build upper layer secure services such as end-user authentication, network communications, and other similar services.

8.3.11.4 Assessment

8.3.11.4.1 Assessment objective

The purpose of this assessment is to confirm that the cryptographic features exposed to the platform users comply with defined best practices.

8.3.11.4.2 Assessment preparation

High level description of the implementation of the secure cryptographic features technical requirement including at minimum where applicable:

— the algorithm name,

— the algorithm use,

— the algorithm method,

— the key size,

— the entropy source.

Platform implementation information in the form of description and/or source code and/or platform samples (representative of the product to be put on the market).

8.3.11.4.3 Assessment activities

8.3.11.4.3.1 Input verification

The input verification for each aspect of the secure cryptographic features requirement relies on the activities outlined in Table 44 below.

Table 44 — TR_CRY input verification activities

Requirement aspects	Verification activities
Best practices	Verify that the description of the secure cryptographic features implementation justifies how those features comply with best practices defined in [3].

8.3.11.4.3.2 Functional testing

The functional testing of each aspect of the secure cryptographic features requirement includes at minimum the testing steps outlined in Table 45 below.

Table 45 — TR_CRY functional testing activities

Requirement aspects	Verification steps
Best practices	— Test each aspect of the algorithm described in [3]. Compliance may be demonstrated through recognized cryptographic certification such as AIS31, FIPS or CAVP, or tests with equivalent coverage (in particular suitable for legacy platforms).

8.3.11.4.3.3 Resistance testing

The resistance level is assessed by conducting analysis and/or testing to ensure that the secure cryptographic feature is protected against attacks, in accordance with instructions from 5.2.4.4.4 and based on the specific aspects described in following:

The relevant attack scenarios are those targeting the security properties of data used in or protected by the designated cryptographic operations.

Such activities are expected to be applied across all relevant parts of the requirement implementation, including, where claimed, those listed in Table 46 below.

Table 46 — TR_CRY resistance testing activities

Requirement aspects	Target of test/analysis
Best practices	— Exposed software and hardware interfaces related to cryptographic features; — Key generation, derivation, storage, retrieval, wrapping, destruction; — RNG nonce/IV generation; — Signature, MAC, Hash generation, verification; — Encryption/Decryption; — Certificates validation and management.

8.3.11.4.4 Assessment verdict

The verdict is assigned as defined in 5.2.5.

8.3.11.4.5 Assessment evidence

Evidence as listed in 5.2.6.

8.3.12 TR_REP Reporting of security events

8.3.12.1 Requirement

The platform shall implement a functionality to monitor, record, and report security-related events.

NOTE 1 Opt-out mechanism option for user is not applicable to platforms as they are only interfacing with dependent components and not directly to users.

1199 NOTE 2 The term record is used here to include permanent or temporary storage.

1200 8.3.12.2 Implementation options

1201 The reporting of security events feature shall be implemented using one of the options (black bullets) for each
1202 applicable requirement aspect specified in Table 47 below.

1203 **Table 47 — TR_REP implementation options**

Requirement aspects	Implementation options
Monitoring of security-related events	— Implementation of physical incident detectors, such as but not limited to: — Hardware sensors monitoring of operating voltage, clock frequency, temperature range, and pins voltage levels; — Bus-error and peripheral fault detection registers; — Memory Protection/Management Unit fault detectors. — Implementation of software-based incident detectors, such as but not limited to: — Boot failure, firmware integrity/authenticity verification failure, unexpected mode transition; — Runtime traps for security related failures/exceptions; — Failed authentication attempts counter. — Combination of above options.
Recording of security-related events	— Storage in volatile memory; — Storage in non-volatile memory; — Storage in register bits/flags; — Storage with additional properties such as timestamping; — Combination of above options.
Reporting of security-related events	— Immediate reporting to the relevant dependent component upon detection of security event; — Periodic or threshold-based reporting of accumulated security-related events; — On-demand reporting of accumulated security-related events triggered by request from dependent component; — Triggered by a specific platform event; — Variant or alternative meeting the requirement; — Combination of above options.

1204 8.3.12.3 Applicability

1205 This technical requirement applicability is determined based on the platform risk assessment.

1206 It is mandatory for platforms of category PTF-SER that claim to offer reporting of security events.

1207 However, recording of the security events may be technically infeasible (e.g. limited or absence of internal
1208 memory), in which case this is part of the platform security guidance (see 8.4.1).

1209 It is intended for platforms that are to be integrated into devices that are themselves part of systems designed
1210 to monitor the operational state of their constituent devices.

prEN 50766:2026 (E)**8.3.12.4 Assessment****8.3.12.4.1 Assessment objective**

The purpose of this assessment is to confirm the ability of the platform to produce and transmit all required security events notifications.

8.3.12.4.2 Assessment preparation

High level description of the implementation of the secure reporting technical requirement.

Platform implementation information in the form of description and/or source code and/or platform samples (representative of the product to be put on the market).

8.3.12.4.3 Assessment activities**8.3.12.4.3.1 Input verification**

The input verification for each aspect of the reporting of security events requirement relies on the activities outlined in Table 48 below.

Table 48 — TR_REP input verification activities

Requirement aspects	Verification activities
Monitoring of security-related events	Verify that the description of the reporting of security events implementation justifies how the platform ensures the identification and monitoring of security-related events, in accordance with the defined implementation options.
Recording of security-related events	Verify that the description of the reporting of security events implementation justifies how the platform ensures the recording of security-related events, in accordance with the defined implementation options.
Reporting of security-related events	Verify that the description of the reporting of security events implementation justifies how the platform ensures the transmission of security-related events, in accordance with the defined implementation options.

8.3.12.4.3.2 Functional testing

The functional testing of each aspect of the reporting of security events requirement includes at minimum the testing steps outlined in Table 49 below.

Table 49 — TR_REP functional testing activities

Requirement aspects	Verification steps
Monitoring of security-related events Recording of security-related events Reporting of security-related events	1. Intentionally trigger predefined security-related events, then verify the reporting behaviour according to the implementation option: a. Immediate: verify that each event is directly transmitted to the designated dependent component upon detection; b. Periodic or threshold-based: verify that the accumulated set of events is complete and reported after end of the defined time interval or once the threshold is reached; c. On-demand: verify that the accumulated set of events is complete and reported when the reporting interface is explicitly invoked.

8.3.12.4.3.3 Resistance testing

The resistance level is assessed by conducting analysis and/or testing to ensure that the reporting of security events feature is protected against attacks, in accordance with instructions from 5.2.4.4.4 and based on the specific aspects described in following:

The relevant attack scenarios are those targeting the integrity of the reporting content.

Such activities are expected to be applied across all relevant parts of the requirement implementation, including at minimum those listed in Table 50 below.

Table 50 — TR_REP resistance testing activities

Requirement aspects	Target of test/analysis
Monitoring of security-related events Recording of security-related events Reporting of security-related events	— Exposed logical and physical interfaces related to reporting of security events feature; — Detection mechanism; — Storage of security-related event information; — Transmission preparation.

8.3.12.4.4 Assessment verdict

The verdict is assigned as defined in 5.2.5.

8.3.12.4.5 Assessment evidence

Evidence as listed in 5.2.6.

8.3.13 TR_AVS Advanced availability support of basic and essential functions**8.3.13.1 Requirement**

The platform shall implement software and/or hardware mechanisms to enhance the availability of basic and essential functions.

NOTE 1 The intended purpose of the platform is to support the reliable execution of the dependent components; the basic and essential functions directly and/or indirectly support the operation of the applicable technical requirements.

NOTE 2 An example of mechanism supporting the availability of essential and basic functions of a platform is a watchdog detecting never-ending execution of a security functionality.

8.3.13.2 Implementation options

The advanced availability support feature shall be implemented using one of the options (black bullets) specified in Table 51 below.

NOTE The availability of the basic and essential functions of the platform is already supported by several other technical requirements, such as secure implementation, secure configuration, secure initialization, secure updates, isolation and tamper-resistance. The implementation options proposed here to complement those protections, providing additional layer of resilience beyond the foundational security mechanisms based on dedicated features.

Table 51 — TR_AVS implementation options

Requirement aspects	Implementation options
Availability support	— Hardware level reliability mechanisms, such as but not limited to: — Watchdog timer; — Error Detection/Correction Code (EDC/ECC); — Redundancy of hardware components e.g. processing units, memory;

Requirement aspects	Implementation options
	— Independent clock fail-safe circuitry; — Independent power source (e.g. battery backup mechanism). — Software level reliability mechanisms, such as but not limited to: — Supervision of tasks/processes related to functions to detect unresponsive behaviour; — Redundancy of routines or structures related to the functions execution; — Periodic checkpointing with rollback capability upon detection of unresponsive behaviour; — Software watchdogs, such as logical timers embedded in tasks/processes related to functions.

8.3.13.3 Applicability

This technical requirement applicability is determined based on the platform risk assessment.

It is mandatory for platforms of category PTF-ADV that claim to deliver enhanced resilience capabilities.

It is intended for platforms that are to be integrated into devices where system uptime, fault tolerance, and continuous operation are important.

8.3.13.4 Assessment

8.3.13.4.1 Assessment objective

The purpose of this assessment is to confirm the activation and efficiency of the advanced availability mechanisms.

8.3.13.4.2 Assessment preparation

High level description of the implementation of the availability of basic and essential functions technical requirement.

Platform implementation information in the form of description and/or source code and/or platform samples (representative of the product to be put on the market).

8.3.13.4.3 Assessment activities

8.3.13.4.3.1 Input verification

The input verification for each aspect of the advanced availability support requirement relies on the activities outlined in Table 52 below.

Table 52 — TR_AVS input verification activities

Requirement aspects	Verification activities
Availability support	Verify that the description of the advanced availability support mechanism justifies how the platform first identifies and then ensures the availability of its essential and basic functions, in accordance with the defined implementation options.

8.3.13.4.3.2 Functional testing

The functional testing of each aspect of the advanced availability support requirement includes at minimum the testing steps outlined in Table 53 below.

1278

Table 53 — TR_AVS functional testing activities

Requirement aspects	Verification steps
Availability support	Apply stress conditions on each identified basic and essential function to intentionally block its execution, then: — Verify that the function continues to operate, either continuously or after a system reset.

1279 **8.3.13.4.3 Resistance testing**

1280 The resistance level is assessed by conducting analysis and/or testing to ensure that the advanced availability
 1281 support mechanism is protected against attacks, in accordance with instructions from 5.2.4.4.4 and based on
 1282 the specific aspects described in following:

1283 The relevant attack scenarios are those targeting the advanced availability support mechanisms themselves to
 1284 provoke the unavailability of the platform security functionalities.

1285 Such activities are expected to be applied across all relevant parts of the requirement implementation, including
 1286 at minimum those listed in Table 54 below.

1287

Table 54 — TR_AVS resistance testing activities

Requirement aspects	Target of test/analysis
Availability support	— Exposed software and hardware interfaces related to availability support feature; — Detection of the function unavailability, identifying when a basic and essential function fails to execute or respond; — Function recovery process, enabling restoration of the affected function.

1288 **8.3.13.4.4 Assessment verdict**

1289 The verdict is assigned as defined in 5.2.5.

1290 **8.3.13.4.5 Assessment evidence**

1291 Evidence as listed in 5.2.6.

1292 **8.3.14 SRD_RST Reset of platform to initial state**1293 **8.3.14.1 Requirement**

1294 The platform shall implement a mechanism to reset to a known secure initial state.

1295 **8.3.14.2 Implementation options**

1296 The platform reset feature shall be implemented using one of the options (black bullets) specified in Table 55
 1297 below.

Table 55 — TR_RST implementation options

Requirement aspects	Implementation options
Reset to a secure initial state	— Hardware mass erase, totally wiping the non-volatile memory content; — Erase of user-specific data, potentially preserving other platform data and/or firmware; — Erase or restore of configuration data; — Variant or alternative meeting the requirement; — Combination of above options.

8.3.14.3 Applicability

This technical requirement applicability is determined based on the platform risk assessment.

It is mandatory for platforms of category PTF-SER that claims the capability of the platform to reset to secure initial state.

It is intended for platforms that are to be integrated into devices that:

- Support multiple owners which therefore require platform reset between two ownership transitions, and/or
- Support the return to manufacturer for failure analysis, for which case erasure of user data are expected for confidentiality concern;
- Requires to be able to restore to a trusted baseline in the event of a malfunction or lockdown, for instance to help preventing product return by enabling recovery.

8.3.14.4 Assessment**8.3.14.4.1 Assessment objective**

The purpose of this assessment is to confirm the ability of the platform to reset to the expected initial state.

8.3.14.4.2 Assessment preparation

High level description of the implementation of the reset technical requirement.

Platform implementation information in the form of description and/or source code and/or platform samples (representative of the product to be put on the market).

8.3.14.4.3 Assessment activities**8.3.14.4.3.1 Input verification**

The input verification for each aspect of the reset requirement relies on the activities outlined in Table 56 below.

Table 56 — TR_RST input verification activities

Requirement aspects	Verification activities
Reset to a secure initial state	Verify that the description of the platform reset implementation justifies how the platform is able to reset to a secure initial state, in accordance with the defined implementation options.

8.3.14.4.3.2 Functional testing

The functional testing of each aspect of the reset requirement includes at minimum the testing steps outlined in Table 57 below.

1323

Table 57 — TR_RST functional testing activities

Requirement aspects	Verification steps
Reset to a secure initial state	- Starting from a platform in its initial state, perform following actions: apply user configurations, load applications where applicable, and invoke features involving user data storage; Trigger a reset of the platform, then: - Verify that all prior user modifications and stored user data have been successfully cleared.

1324 **8.3.14.4.3.3 Resistance testing**

1325 The resistance level is assessed by conducting analysis and/or testing to ensure that the platform reset
1326 mechanism is protected against attacks, in accordance with instructions from 5.2.4.4.4 and based on the specific
1327 aspects described in following.

1328 The relevant attack scenarios are those targeting the confidentiality of platform data by preventing the reset of
1329 user-specific data.

1330 Such activities are expected to be applied across all relevant parts of the requirement implementation, including
1331 at minimum those listed in Table 58 below.

1332

Table 58 — TR_RST resistance testing activities

Requirement aspects	Target of test/analysis
Reset to a secure initial state	- Exposed software and hardware interfaces related to reset feature; - Erase mechanisms invocation.

1333 **8.3.14.4.4 Assessment verdict**

1334 The verdict is assigned as defined in 5.2.5.

1335 **8.3.14.4.5 Assessment evidence**

1336 Evidence as listed in 5.2.6.

1337 **8.3.15 TR_RES Tamper-resistance of platform**1338 **8.3.15.1 Requirement**

1339 The platform shall implement countermeasures against physical attacks including tamper-resistance and/or
1340 tamper-evidence and/or tamper-response mechanisms to protect the selected assets.

1341 **8.3.15.2 Implementation options**

1342 The tamper-resistance of platform against attacks shall be implemented using one of the options (black bullets)
1343 for each applicable requirement aspect specified in Table 59 below., consistently with the platform intended
1344 operational environment and users categories, as defined in 5.2.5:

1345 — All platforms shall implement protections against logical attacks;

1346 — Platforms operating in ENV-NTP shall implement additional protections against physical attacks.

1347 NOTE Protections against logical attacks is already indirectly supported by several other technical requirements, such
1348 as secure implementation, secure configuration, secure initialization, secure updates, isolation and access control. The
1349 implementation options proposed here are additional mechanisms that goes beyond those.

Table 59 — TR_RES implementation options

Requirement aspects	Implementation options
Tamper-resistance	— Protections against logical and/or physical memory dumping/analysis, such as but not limited to: — Memory scrambling, making difficult the reconstruction of raw memory content data (e.g. captured via probes, bus analyser, cold boot attack), targeting of specific memory rows or cells for bit-flipping attacks, code reverse engineering; — Hardware encryption, preventing direct reading of sensitive data from memory, for instance via probing, cold boot attack or DMA (Direct Memory Access), buffer overflow exploitation; — Memory Protection Unit (MPU), Memory Management Unit (MMU) forbidding execution/reading/writing from specific memory segments; — Solutions managing distinct execution domains (e.g. secure and non-secure) protecting from illegal accesses. — Protections against logical and/or physical side channel analysis, such as but not limited to: — Use of cryptographic algorithms implementation protecting against side channel leakage exploitations; — Randomization of execution paths, memory access and/or instruction execution order; — Constant-time programming, preventing leakage exploitation of information via time variation; — Timing noise injection (e.g. jitter, random delays); — Noise injection in or filtering of signal emissions. — Protections against clock manipulations via logical and/or physical interfaces, such as but not limited to: — Deactivation or restriction of access to software interfaces influencing the clock (e.g. Application Programming Interfaces, clock controls registers); — Filtering of out of range or malformed clock pulses. — Protections against other logical and/or physical fault injections, such as but not limited to: — Redundant execution of security-related operations, comparing results to detect potential faults; — Redundant checks of security related conditions or values; — Error detection/correction code, detecting/correcting memory and buses corruptions. — Protections against low-complexity physical access, such as but not limited to: — Disabling of unused hardware interfaces to reduce tampering attack surfaces. — Protection against micro-architectural attacks via logical and/or physical interfaces where applicable, such as but not limited to: — Software and/or hardware counter measures against speculative execution controls; — Cache flushing during context switches;

Requirement aspects	Implementation options
	— Page partitioning avoiding cache line sharing between processes; — Constant-time programming avoiding data-dependent branching and memory access patterns to mitigate side channel exploitation. — Variant or alternative meeting the requirement; — Combination of above options.
Tamper-evidence	— Detection of tampering attempt mechanism via physical or logical interfaces, such as but not limited to: — Monitoring of voltage, temperature, and frequency out of range; — Storage of information of tamper-events (e.g. timestamp, source/type of tamper); — Clock watchdog, monitoring unexpected frequency changes or jitter; — Memory Protection Unit (MPU), Memory Management Unit (MMU), triggering runtime exceptions for illegal memory accesses. — Stack canaries, detecting stack buffer overflows. — Visual aspect of the packaging, making physical intrusion attempts evident. — Monitoring mechanisms of platform execution, targeting for instance: — Control flow integrity; — Tasks/processes behaviour. — Variant or alternative meeting the requirement; — Combination of above options.
Tamper-response	— Reset to restart operation, or process the notification in software, or halt operation and reach a safe state; — Erasing of part of or all sensitive data as described in 8.3.6.2, for instance either by an automated hardware reaction, or by firmware/software operation after evaluation of the tamper evidence; — Disabling of part of or all functionalities to mitigate further tamper attempts, either permanently or until the next device reset/restarts; — Reporting of the security event to external component; — Triggering of an exception with specific treatment for each tampering; — Variant or alternative meeting the requirement; — Combination of above options. NOTE Any response to the tamper attempt might be either of temporary or permanent effect, depending on the device capability and where the behaviour is selectable, on the risk assessment

1351 **8.3.15.3 Applicability**

1352 This technical requirement is mandatory.

1353 **8.3.15.4 Assessment**

1354 **8.3.15.4.1 Assessment objective**

1355 The purpose of this assessment is to confirm the activation and efficiency of the tamper-resistance mechanisms.

prEN 50766:2026 (E)**8.3.15.4.2 Assessment preparation**

High level description of the implementation of the physical tamper-resistance technical requirement.

Platform implementation information in the form of description and/or source code and/or platform samples (representative of the product to be put on the market).

8.3.15.4.3 Assessment activities**8.3.15.4.4 Input verification****8.3.15.4.4.1 General**

The input verification for each aspect of the physical tamper-resistance requirement relies on the activities outlined in Table 60 below.

Table 60 — TR_RES input verification activities

Requirement aspects	Verification activities
Tamper-resistance	Verify that the description of the tamper-resistance mechanisms justifies how the platform protects itself against attacks, in accordance with the defined implementation options. Verify in particular that potential cryptographic usage complies with best practices defined in [3].
Tamper-evidence	Verify that the description of the tamper-resistance mechanisms justifies how the platform detects attacks, in accordance with the defined implementation options.
Tamper-response	Verify that the description of the tamper-resistance mechanisms justifies how the platform reacts to attacks, in accordance with the defined implementation options.

8.3.15.4.4.2 Functional testing

The functional testing of each aspect of the physical tamper-resistance requirement is covered through the input and resistance verifications.

8.3.15.4.4.3 Resistance testing

The resistance level is assessed by conducting penetration testing of the logical and physical interfaces of the platform (e.g. memories, CPUs, communication ports) specifically targeting its implemented security functionalities. The penetration testing campaign is performed in accordance with instructions from 5.2.4.4.4 and based on the specific aspects described in following:

The relevant attack scenarios are those targeting the security properties of any platform asset.

8.3.15.4.4.4 Assessment verdict

The verdict is assigned as defined in 5.2.5.

8.3.15.4.5 Assessment evidence

Evidence as listed in 5.2.6.

8.4 Technical requirements related to platform operation

8.4.1 TR_SEG Application of platform security guidance

8.4.1.1 Requirement

Platform security guidelines shall include comprehensive instructions to ensure the secure operation of platform security functionalities.

NOTE Security guidance includes the secure handling of material by the operational environment and secure configuration when applicable.

8.4.1.2 Implementation options

The platform security guidance shall at minimum includes the following content:

- If both secure and non-secure variants of a given technical requirement exist, explicit statement that only the secure variant is permitted for the relevant applicability.

EXAMPLE Non-secure boot processes, non-secure storage features, or cryptographic functionalities that do not adhere to best practices.

- If assets can be put out of the platform control, description of appropriate protections to be implemented by the operational environment.

EXAMPLE Cryptographic private keys externally stored outside of the platform control.

- Description of potential protections or organizational measures to be implemented by the operational environment to ensure the security of the platform.

- Description of security configurations to be applied before delivery to end-users in order to ensure platform security.

EXAMPLE Deactivation of debug features or life cycle state update.

- List of the security functionalities which can be disabled by platform configuration along with the security limitations.

EXAMPLE Disabling of the reset of platform to initial state due to intermediate user (e.g. system integrator) own risk assessment.

- Explicit statement of delegation of full or part of technical requirement to another component outside the scope of the platform. This can concern in particular the following technical requirements:

- Support to the secure initialization of dependent component (see 8.3.3.3);

- Secure update of dependent components (see 8.3.5.3).

- Any restriction of use to a specific environment or users category (see 5.2.5). This can concern in particular the following technical requirements:

- Isolation of the platform from its logical environment (see 8.3.7.3).

- Any design or technical constraints preventing the implementation of a full or part of a technical requirement, along with any resulting usage limitation and/or potential compensating measures to be applied at dependent component level to address the identified gap. This concerns in particular the following technical requirements:

- Secure update of platform (see 8.3.4.3)

prEN 50766:2026 (E)

— Integrity and authenticity platform firmware verification (see 8.3.3.3);

— Secure erasure of data (see 8.3.6.3)

— Recording of the reporting of security events features (see 8.3.12.3).

8.4.1.3 Applicability

This technical requirement is mandatory.

8.4.1.4 Assessment**8.4.1.4.1 Assessment objective**

The purpose of this assessment is to confirm the availability of all guidance necessary to maintain the security functionalities of the platform throughout its entire life cycle after deployment.

8.4.1.4.2 Assessment preparation

Platform security guidance providing all information needed for the secure use of the platform, including:

— where applicable, description for secure configuration of the platform by the integrator before being put on the market for final users;

— identification of the material to be handled by the operational environment and requirements for secure handling.

Platform implementation information in the form of description and/or source code and/or platform samples (representative of the product to be put on the market).

8.4.1.4.3 Assessment activities**8.4.1.4.3.1 Input verification**

The input verification for the platform security guidance requirement relies on the activities outlined in Table 61 below.

Table 61 — TR_SEG input verification activities

Requirement aspects	Verification activities
Application of platform security guidance	Verify that security guidance for the secure configuration and use of the platform is available and complete, and are at a sufficient level of granularity to ensure the maintenance of the platform security.

8.4.1.4.3.2 Functional testing

Not applicable.

8.4.1.4.3.3 Resistance testing

Not applicable.

8.4.1.4.4 Assessment verdict

The verdict is assigned as defined in 5.2.5.

8.4.1.4.5 Assessment evidence

Evidence as listed in 5.2.6.

Annex A (informative)

Security analysis

A.1 General

This annex presents a generic security analysis framework for platforms, with the objective of specifying the technical requirements that the platform shall implement to fulfil its intended security purpose, taking into account context described in 5.2.5.

This generic security analysis aligns with the principles described in [1] Clause 5 with adaptations to the specific context of the platform.

This Annex also intent to provide transparency to products integrating the platform, by detailing the security aspects addressed by the platform for each fulfilled technical requirements.

The security analysis, which serves as the foundation for defining the platform technical requirements to be implemented, follows the steps detailed in this Annex:

- Identification of the assets and their properties (A.2);
- Identification of the incidents to be prevented to protect the assets (A.3);
- Determination of threats that could lead to each identified incidents (A.4.2);
- Specification of organisational security policies to be enforced by the product and/or its environment (A.4.3);
- Specification of assumptions on this environment shall be identified for the completeness of security objectives (A.4.4);
- Consolidation of security objectives based on the above inputs (A.5);
- Determination of risk environments to identify the protections required to ensure the appropriate robustness to the platform intended purpose (A.6).

These security analysis steps are represented in Figure 1 below.

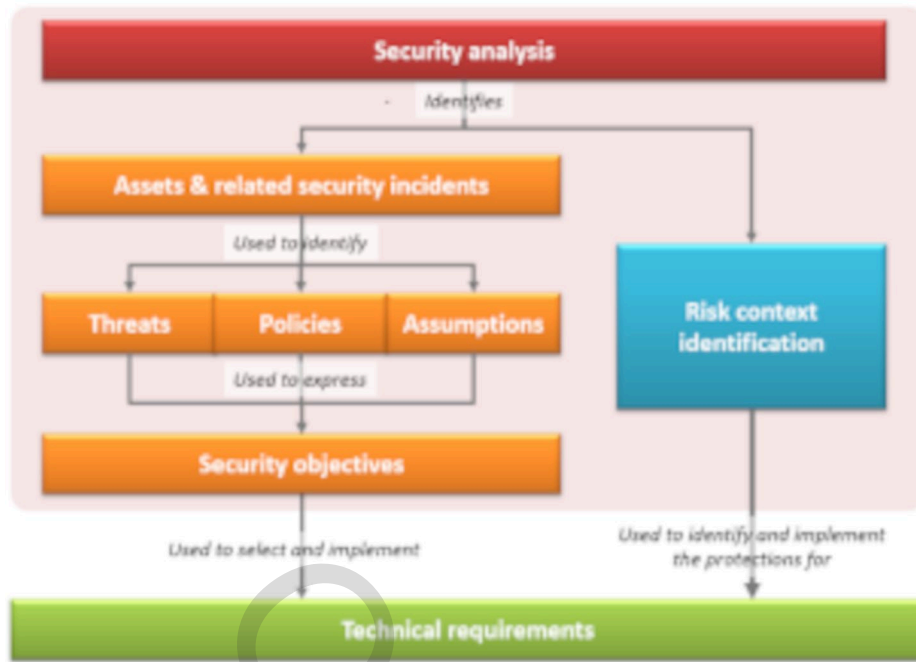


Figure 1 — Security analysis principles

A.2 Assets

The platform assets and their properties are listed in Table A.1 below:

Table A.1 — Platform assets and properties

Assets	Properties to be protected	Comments
Platform data with security properties (sensitive data)	Confidentiality, integrity, authenticity, availability	Platform data are data handled by the platform including manufacturer data, user code and user data. These data with security properties can be stored locally or remotely; a part of can also be processed remotely.
Platform code	Integrity, authenticity	Code confidentiality is not mandatory as the security of a product cannot rely on its code confidentiality but on the absence of vulnerability and the efficiency of countermeasures.
Security functionalities	Access, execution integrity, availability	Due to potential damage to assets that security functionalities may cause, there often needs to be restrictions in terms of access.
Resources of external entities	Access, availability	The platform may have an impact on the assets and/or resources of entities it is exchanging with (e.g. application software on top, remote server) in case the platform has privileged access to those entities based on its authentication.

Certain data and functions included in the product are not security-relevant, and therefore do not require protection.

The platform security analysis may need to refine this asset list based on knowledge of the platform.

A.3 Security incidents

A.3.1 General

This section identifies the incidents to be prevented in relation to the assets identified in Clause A.2. These incident scenarios need to be refined in the specific platform security analysis, taking into account the specific characteristics of the platform, and in accordance to the refined list of assets.

A.3.2 PI_DUD Disclosure of user data

This potential incident corresponds to the loss of the confidentiality property on user data.

A.3.3 PI_MUD Manipulation of user data

This potential incident corresponds to the loss of the integrity and authenticity properties on user data, due to data deletion, modification or replacement.

A.3.4 PI_MBD Modification of the behaviour of the device

This potential incident corresponds to the unexpected modification of the behaviour of the device caused by an incident on the platform, affecting its security functionalities, due to code or data modification or replacement.

A.3.5 PI_MCD Malicious control of the device

This potential incident corresponds to an unauthorized entity taking control of the device caused by an incident on the platform.

A.3.6 PI_UEB Unavailability of essential and basic functions of the device

This potential incident corresponds to the loss of the availability property on essential and basic functions of the device caused by an incident on the platform.

A.3.7 PI_MDO Malicious use of the device against other devices or networks

This potential incident corresponds to damaging other devices and networks, including illegal access (e.g. by impersonation) and denial of service, caused by an incident on the platform.

A.3.8 Completeness of incidents identification

Table A.2 below shows the completeness of the identification of incidents related to the list of assets identified in Clause A.2.

Table A.2 — Platform asset properties vs potential incidents

Assets properties	Incidents related to assets properties
Platform data confidentiality	PI_DUD Disclosure of user data
Platform data integrity	PI_MUD Manipulation of user data (data modification)
Platform data authenticity	PI_MUD Manipulation of user data (data replacement)
Platform code integrity	PI_MBD Modification of the behaviour of the device (code modification)
Platform code authenticity	PI_MBD Modification of the behaviour of the device (code replacement)
Security functionalities access	PI_DUD Disclosure of user data PI_MUD Manipulation of user data

Assets properties	Incidents related to assets properties
	PI_MCD Malicious control of the device PI_MDO Malicious use of the device against other devices or networks
Security functionalities execution	PI_DUD Disclosure of user data PI_MUD Manipulation of user data PI_MBD Modification of the behaviour of the device PI_MCD Malicious control of the device PI_MDO Malicious use of the device against other devices or networks PI_UEB Unavailability of essential and basic functions of the device
Security functionalities availability	PI_UEB Unavailability of essential and basic functions of the device
Resources of external entities access	Incidents on external to be determined by the external entities
Resources of external entities availability	Incidents on external to be determined by the external entities

A.4 Security problem definition

A.4.1 General

The security problem definition aims at identifying the factors allowing or preventing the realization of the incidents identified in Clause A.3. Those factors are described in detail in the next subclauses.

A.4.2 Threats

A.4.2.1 General

The threats considered in this document are threats against the platform which can lead to the realization of the incidents at device level identified in Clause A.3.

The threats can be described at different level of granularity depending on the knowledge of the platform and on its environment. The threats listed in This subclause are at the highest level of granularity because based on knowledge generic to all platform and platform environment.

The platform security analysis needs to refine the threats applicable to the platform based on the knowledge of the platform and consistently with the specifically refined list of incidents.

A.4.2.2 T_UDD Unauthorized disclosure of data that needs to be protected in confidentiality

This threat corresponds to the loss of confidentiality of data requiring it and handled by the platform. This threat can materialize during storage, processing, or communication of data.

A.4.2.3 T_UMD Unauthorized modification of data that needs to be preserved in integrity

This threat corresponds to the loss of integrity of data requiring it and is and handled by the platform. This threat can materialize during storage, processing, or communication of data.

A.4.2.4 T_UMC Unauthorized modification of code running on the platform

This threat corresponds to the loss of integrity of the code or of its control flow. This threat can materialize in particular during initialization, update and execution.

A.4.2.5 T_CCF Compromise of a cryptographic security functionality

If the platform provides cryptographic security functionality this threat corresponds to its compromise.

1529 NOTE 1 Compromise can result from a weak algorithm or by exploiting implementation vulnerabilities.

1530 NOTE 2 Threats related to cryptography used internally to implement security functionalities (integrity or confidentiality
1531 protection of data for example) are handled by the other threats.

1532 **A.4.2.6 T_UAF Unauthorized access to the security functionalities of the platform**

1533 This threat corresponds to the bypass of the mechanism restricting the access to the security functionalities
1534 exposed by the platform.

1535 **A.4.2.7 T_DBF Disruption of essential and basic functions of the platform**

1536 This threat corresponds to preventing the platform from providing essential and basic functions, including by
1537 denial-of-service attacks.

1538 NOTE The essential and basic functions need to be identified.

1539 **A.4.2.8 T_PER Impersonation of the platform**

1540 This threat corresponds to the platform (or some of its components) being replaced or cloned by a malicious
1541 one.

1542 **A.4.3 Organizational security policies**

1543 **A.4.3.1 General**

1544 The organisational security policies are the rules or processes mandatory to be applied on the platform or its
1545 environment to ensure the platform security functionalities.

1546 The platform security analysis may need to refine the security policies applicable to its platform based on the
1547 knowledge of the platform specificities.

1548 **A.4.3.2 SP_IMP Implementation best practices**

1549 The platform is implemented following secure implementation rules covering common good practices for secure
1550 design and implementation, at minimum including principles described in [1] 5.3.

1551 **A.4.3.3 SP_CFG Secure configuration of platform**

1552 The platform is released in a secure configuration that protects the platform assets, following at minimum
1553 principles described in [1] 5.4. When the integrator is trusted based on legal contractual support, the protection
1554 of the platform assets during integration phase can be covered by organizational measures.

1555 **A.4.4 Security assumptions**

1556 **A.4.4.1 General**

1557 The security assumptions are the assumptions to be made on the environment of the platform to ensure the
1558 platform security functionalities.

1559 The platform security analysis may need to refine the security assumptions on the platform environment based
1560 on the knowledge of the platform specificities.

1561 **A.4.4.2 SA_SEG Application of platform security guidance**

1562 Platform security guidelines are followed or replaced by measures ensuring the same security.

1563 NOTE Platform security guidelines include any platform configuration needed by the integrator and how to handle any
1564 security-related material handled out of the platform.

A.4.5 Risks analysis coverage

Table A.3 below shows the full coverage of the risk analysis by the threats.

Table A.3 — Threats vs incidents

Incidents	Security problem definition
PI_DUD Disclosure of user data	T_UDD Unauthorized disclosure of data that needs to be protected in confidentiality
PI_MUD Manipulation of user data	T_UMD Unauthorized modification of data that needs to be preserved in integrity
PI_MBD Modification of the behaviour of the device	T_UMC Unauthorized modification of code running on the platform T_CCF Compromise of a cryptographic security functionality
PI_MCD Malicious control of the device	T_UAF Unauthorized access to the security functionalities of the platform T_UMC Unauthorized modification of code running on the platform
PI_UEB Unavailability of essential and basic functions of the device	T_DBF Disruption of essential and basic functions of the platform
PI_MDO Malicious use of the device against other devices or networks	T_UAF Unauthorized access to the security functionalities of the platform T_PER Impersonation of the platform

A.5 Security objectives

A.5.1 General

The security objectives are the expression of what needs to be fulfilled by the platform and its environment to solve the security problem definition and then ensure the platform security functionalities.

Security objectives can be defined for the platform implementation or for the platform environment.

The list of generic security objectives listed in this subclause may need to be refined based on the knowledge of the platform specificities as described in Clause A.2 and consistently with the potentially specifically refined security problem definition.

A.5.2 Security objectives for the platform

A.5.2.1 SOP_IMP Implementation best practices

The platform shall follow secure implementation rules covering best practices for secure design and coding, at minimum including principles described in [1] 5.3.

A.5.2.2 SOP_CFG Secure configuration of platform

The platform shall be released in a secure configuration that protects the platform assets, following at minimum principles described in [1] 5.4. When the integrator is trusted based on legal contractual support, the protection of the platform assets during integration phase can be covered by organizational measures.

A.5.2.3 SOP_DCP Data confidentiality protection

The platform shall protect the confidentiality of data that needs to be preserved in confidentiality during processing, storage and communication.

A.5.2.4 SOP_DIP Data integrity protection

The platform shall protect the integrity of data that needs to be preserved in integrity during processing, storage and communication.

A.5.2.5 SOP_CIP Code integrity and control flow protection

The platform shall ensure that code executes as expected on the platform and cannot be modified or its execution altered in an unauthorized way during initialization, update or execution.

A.5.2.6 SOP_ACC Access control to platform security functionalities

The platform shall control access to security functionalities so they can only be used by authorized users.

A.5.2.7 SOP_EFA Essential functions availability support

The platform shall protect the availability of the essential functions.

A.5.2.8 SOP_CRY Secure cryptographic features

If the platform provides cryptographic security functionalities, they shall be cryptographically secure and exempt from implementation vulnerabilities.

A.5.2.9 SOP_PAU Authentication of platform

The platform shall ensure its authenticity and the authenticity of its different internal components.

A.5.3 Security objectives for the environment**A.5.3.1 SOE_SEG Platform security guidelines application**

All platform security guidelines for secure integration or usage provided in the platform documentation shall be followed, or be replaced by measures ensuring an equivalent level of security.

NOTE Platform security guidelines include any platform configuration needed for integration and/or usage and how to handle any security-related material handled out of the platform.

A.5.4 Security problem definition coverage

Table A.4 below shows the full coverage of the security problem definition by the security objectives.

Table A.4 — Security problem definition vs security objectives

Security problem definition	Security objectives
T_UDD Unauthorized disclosure of data that needs to be protected in confidentiality	SOP_DCP Data confidentiality protection
T_UMD Unauthorized modification of data that needs to be preserved in integrity	SOP_DIP Data integrity protection
T_UMC Unauthorized modification of code running on the platform	SOP_CIP Code integrity and control flow protection
T_CCF Compromise of a cryptographic security functionality	SOP_CRY Secure cryptographic features
T_UAF Unauthorized access to the security functionalities of the platform	SOP_ACC Access control to platform security functionalities
T_DBF Disruption of essential and basic functions of the platform	SOP_EFA Essential functions availability support
T_PER Impersonation of the platform	SOP_PAU Authentication of platform

Security problem definition	Security objectives
	SOP_CFG Secure configuration of platform
SP_IMP Implementation best practices	SOP_IMP Implementation best practices
SP_CFG Secure configuration of platform	SOP_CFG Secure configuration of platform
SA_SEG Application of platform security guidance	SOE_SEG Platform security guidelines application

A.5.5 Security objectives coverage

Table A.5 below shows the coverage of the security objectives by the technical requirements identified in Clause 8.

Table A.5 — Security objectives vs technical requirements

Security objectives	Technical requirements
SOP_IMP Implementation best practices	TR_IMP Implementation best practices
SOP_CFG Secure configuration of platform	TR_CFG Secure configuration of platform
SOP_DCP Data confidentiality protection	TR_EXP No known exploitable vulnerabilities
	TR_INI Secure initialisation support
	TR_SUP Secure update of platform
	TR_SUD Secure update of dependent components
	TR_PID Identification of platform
	TR_ERA Secure erasure of data
	TR_ISO Isolation mechanisms
	TR_RES Tamper-resistance of platform
	TR_STO Secure storage
	TR_COM Secure communication
	TR_REP Reporting
SOP_DIP Data integrity protection	TR_EXP No known exploitable vulnerabilities
	TR_INI Secure initialisation support
	TR_SUP Secure update of platform
	TR_SUD Secure update of dependent components
	TR_PID Identification of platform
	TR_ISO Isolation mechanisms
	TR_RES Tamper-resistance of platform
	TR_STO Secure storage
	TR_COM Secure communication
SOP_CIP Code integrity and control flow protection	TR_EXP No known exploitable vulnerabilities
	TR_INI Secure initialisation support
	TR_SUP Secure update of platform
	TR_SUD Secure update of dependent components

Security objectives	Technical requirements
	TR_PID Identification of platform
	TR_ISO Isolation mechanisms
	TR_RES Tamper-resistance of platform
	TR_REP Reporting
SOP_ACC Access control to platform security functionalities	TR_EXP No known exploitable vulnerabilities
	TR_INI Secure initialisation support
	TR_SUP Secure update of platform
	TR_SUD Secure update of dependent components
	TR_PID Identification of platform
	TR_RES Tamper-resistance of platform
	TR_ACC Access control to security functionalities
	TR_REP Reporting
SOP_EFA Essential functions availability support	TR_EXP No known exploitable vulnerabilities
	TR_INI Secure initialisation support
	TR_SUP Secure update of platform
	TR_SUD Secure update of dependent components
	TR_PID Identification of platform
	TR_ISO Isolation mechanisms
	TR_RES Tamper-resistance of platform
	TR_AVS Advanced availability support of basic and essential functions
SOP_CRY Secure cryptographic features	TR_EXP No known exploitable vulnerabilities
	TR_INI Secure initialisation support
	TR_SUP Secure update of platform
	TR_SUD Secure update of dependent components
	TR_PID Identification of platform
	TR_ISO Isolation mechanisms
	TR_RES Tamper-resistance of platform
	TR_CRY Secure cryptographic features
SOP_PAU Authentication of platform	TR_EXP No known exploitable vulnerabilities
	TR_INI Secure initialisation support
	TR_SUP Secure update of platform
	TR_SUD Secure update of dependent components
	TR_PID Identification of platform
	TR_PAU Authentication of platform
	TR_ISO Isolation mechanisms
	TR_RES Tamper-resistance of platform

Security objectives	Technical requirements
SOE_SEG Platform security guidelines application	TR_SEG Application of platform security guidance

A.6 Risk environments

A.6.1 General

The risk environments are defined by the set of environmental factors that determines to which risks devices are exposed, i.e. different likelihood and consequences of the incidents identified in Clause A.3, and consequently which threats identified in A.4.2 are to be countered by the underlying platform. Based on the defined risk environments, the necessary security functionalities and their required resistance level are selected to prevent the occurrence of these risks.

Platforms may be integrated in different devices and then exposed to different risk environments. Therefore the risk environments are to be defined at a higher level, at minimum at the device level where the intended purpose is known. The information of which incidents are covered by the platform security functionalities implemented and to which attacks the platforms can resist then need to be made transparent to allow the dependent components up to the device to choose a platform suitable for their operational risk environment.

The list of security functionalities a platform can claim, described in Clause 8, is derived from the security analysis detailed in previous clauses of this annex and is specific to platforms.

The expected resistance of a platform to attacks, also called attack potential, still needs to be defined in a way that is usable at higher levels to assess suitability for a given risk environment. A widely recognized framework for defining attack potential levels is provided in [13]. This framework is used in this document, to define the attack potentials of the platforms in scope, specifically limited to AVA_VAN.2 (Basic) and AVA_VAN.3 (Enhanced-Basic).

Resistance to AVA_VAN.2 attack potential is intended for platforms to be integrated into devices whose risk assessment has identified the need to resist to attackers with limited capabilities in terms of expertise and/or equipment. This level is intended to counter the simplest and potentially most frequent attacks in the field, making it suitable for addressing low-impact risks.

Resistance to AVA_VAN.3 attack potential is intended for platforms to be integrated into devices whose risk assessment has identified the need to resist to attackers with higher capabilities than those considered under AVA_VAN.2. This level is intended to ensure protection against attackers with greater motivation and resources, and to mitigate attacks that could result in higher negative impacts, in particular financial and reputational, for the manufacturers and vendors involved.

A.6.2 Example of platform risk environment (attack potential) information reuse

An example of risk environment definition can be based on [2] specifying concepts and methodology for the harmonized security assessments of the different market sectors (or application areas). Following this standard, the risk environments aspects are covered by the following concepts:

- the meta-risk classes (MRCs) described in [2], 7.1;
- the attack potential levels (APL) described in [2], 6.3.8.

As shown in [2] Figure 1, 5.1 both the meta-risk classes and the attack potential levels are inputs for the selection of the appropriate technical requirements (via the concept of common security levels and security controls described in [2], 7.2 and resistance level (via the concept of common assurance reference described in [2], 7.2.6).

In the [2], risks are to be defined by the stakeholders of each sector and to be prevented by supporting assets. In this context, devices are supporting assets and platforms are components of those supporting assets which are required to provide the base security functionalities for the security controls implementation and to support the appropriate resistance to the targeted attack potential level. Also, in this standard the attack potential levels

1657 are mapped to the ones defined in [13] via the concept of common assurance references in [13], 7.2.6 and in
1658 the analysis done in [13], B.5.6.

Ontwerp
Draft

Annex B (informative)

Platform categories and applicability overview

Table B.1 summarizes platform categories, associated technical requirements, their applicability and relevant use cases.

Table B.1 — Platform categories and applicability overview

Platform categories	Applicable technical requirements	Applicability	Use cases
PTF-COR	TR_VUL Vulnerability handling process	Mandatory with no exception	For devices requiring foundational security features to securely build their own intended purpose.
PTF-COR	TR_IMP Implementation best practices	Mandatory with exceptions in case of organizational constraints	
PTF-COR	TR_EXP No known exploitable vulnerabilities	Mandatory with no exception	
PTF-COR	TR_CFG Secure configuration of platform	Mandatory, with exception in case protections are covered by organizational measures	
PTF-COR	TR_PID Identification of platform	Mandatory with no exception	
PTF-COR	TR_INI Secure initialisation support	Mandatory, with exception in case of technical limitations, and under which usage is restricted to the following scenarios: — Environment protections ; — Lifetime shorter than attack exploitation. The specific support to dependent component aspect may be delegated to external component (preferably relying on signature verification based on TR_CRY Secure cryptographic features if available).	
PTF-COR	TR_SUP Secure update of platform	Mandatory, with exception in case of design limitations and technical limitations to patching, and under which usage is restricted to the following scenarios: — Environment protections ; — Compensating measures by external components ; — Lifetime shorter than attack exploitation.	

Platform categories	Applicable technical requirements	Applicability	Use cases
PTF-COR	TR_SUD Secure update of dependent components	Mandatory if dependent components are to be run on the platform, with exception in case implementation is delegated to external component (preferably relying on signature verification based on TR_CRY Secure cryptographic features if available)	
PTF-COR	TR_ERA Secure erasure of data	Mandatory, with exception in case the platform is not intended to handle confidential data, or where erasing is not possible by design, and under which usage is restricted to the following scenarios: — Environnement protections ; — Compensating measures by external components;	
PTF-COR	TR_ISO Isolation mechanisms – between the platform and its environment	Mandatory, with exception in case the platform is intended to be operated in trusted logical environment (ENV-TRL).	
PTF-MTR	TR_RES Tamper-resistance of platform	Mandatory Protections against logical attacks for all platforms. Protection against physical attacks for platforms in ENV-NTP.	For devices that require robustness in their intended function against attacks with a low, but not negligible, attack potential corresponding to AVA_VAN.2 and AVA_VAN.3 as define in [13].
Advanced features PTF-ADV	TR_ISO Isolation mechanisms – between parts of the platform and/or between dependent components dedicated resources	According to risk assessment and aligned with platform claimed security capabilities	For devices that require differential security levels across their own services built upon the platform security features. For devices that need to support multiple isolated instances, to ensure that no single application can compromise the security, stability or performance of other ones by accessing their resources.
	TR_ACC Access control to security functionalities	According to risk assessment and aligned with platform claimed security capabilities	For devices that require multiple users/roles to have different levels of access to the platform security features.
	TR_AVS Advanced availability support of basic and essential functions	According to risk assessment and aligned with platform claimed security capabilities	For devices for which system uptime, fault tolerance and continuous operation are important.

Platform categories	Applicable technical requirements	Applicability	Use cases
Security services PTF-SER	TR_PAU Authentication of platform	According to risk assessment and aligned with platform claimed security capabilities	For devices that need to establish a trusted relationship with external entities, based on verified authenticity, and/or For devices that support the deployment of software in the field, where it is essential to verify the authenticity of the platform on which the software will run.
	TR_STO Secure storage	According to risk assessment and aligned with platform claimed security capabilities	For devices that use the platform to store securely their own assets.
	TR_COM Secure communication	According to risk assessment and aligned with platform claimed security capabilities Mandatory when processing data remotely	For devices that exchange sensitive data, such as personal data, financial details, authentication credentials, and similar types of sensitive content. For platforms that exchange their own sensitive data with another trusted entity, including in case of remote data processing.
	TR_CRY Secure cryptographic features	According to risk assessment and aligned with platform claimed security capabilities	For devices that require a cryptographic foundation to build upper layer secure services as end-user authentication, network communications, and other similar services.
	TR_REP Reporting of security events	According to risk assessment and aligned with platform claimed security capabilities	For devices that are themselves part of systems designated to monitor the operational state of their constituent devices.
	SRD_RST Reset of platform to initial state	According to risk assessment and aligned with platform claimed security capabilities	For devices that support multiple owners, and/or need to be able to restore to a trusted baseline in the event of a malfunction or lockdown.

Annex C (informative)

Support of European security evaluation methodologies

C.1 General

This annex maps input verification, functional testing and resistance testing activities of each technical requirement to the methodologies defined in [11], CC-3 [13] and FITCEM [14] which outline equivalent assessment processes.

This facilitates the harmonization of assessment activities and enables the reuse of the security activities performed during product certifications based on those methodologies.

Additionally, these standards specify a composition process (detailed in [11] Annex E, CC-3 [13] 12.10 and FITCEM [14] 6.13) that ensure the transparency of information for platform integration. This enables the reuse of platform-level security assessments and conclusions when assessing products integrating the platform.

C.2 Compliance demonstration support

C.2.1 Assessment of applicability

The appropriate selection of technical requirements applicability is ensured by security profile documents that aim at harmonizing the security assessment of same type of platform. These profiles specify a consistent set of technical requirements and an assurance level applicable to the targeted platforms. They are developed by expert communities responsible for conducting generic risk assessments for the relevant platform type. As such, security profiles compliant with the following methods justifies the selection of applicable technical requirements:

- SESIP [11] 4.9.2 (SESIP profiles, in particular see Clause C.3 for [8], [9] and [10] profiles), or

- CC-3 [13] 7 (Class APE Protection Profile (PP) evaluation), or

- FITCEM [14] 6.2 (Protection Profile Evaluation).

Alternatively, the verification is also achieved through the use of security target documents listed below that include evidence that applicability has been determined based on a risk assessment:

- SESIP [11] 4.6 (Accessibility and transparency) and 7.2 (Security Target requirements), or

- CC-3 [13] 9 (Class ASE Security Target (ST) evaluation), or

- FITCEM [14] 6.4 (Security Target Evaluation).

Therefore, the compliance to a security profile or security target, at minimum including the mandatory technical requirements specified in this document, may be used to validate the applicability verification required for PASS assessment verdict, as defined in 5.2.5.

C.2.2 TR_IMP Implementation best practices

The application of implementation best practices is verified through the analysis and/or testing of applicable technical requirements.

C.2.3 TR_EXP No known exploitable vulnerabilities

The absence of un-addressed known exploitable vulnerability is verified through the analysis and/or testing of applicable technical requirements.

C.2.4 TR_CFG Secure configuration of platform

The appropriate configuration of the platform is verified through the analysis and/or testing of applicable technical requirements.

C.2.5 TR_PID Identification of platform

Input verification may be performed following one of the methods below:

Table C.1 — TR_PID input verification methods

Assessment method	Specific assessment tasks	Specific technical requirement
SESIP [11]	SESIP [11] 7.2.5 ("ASE_TSS.SESIP")	SESIP [11] 5.2.2 ("Verification of platform identity")
CC-3 [13]	CC-3 [13] 12.2.4 Table 162 ("Labelling of the TOE (ALC_CMC.1)" – ALC_CMC.1.1.E)	Covered by assessment task.
FITCEM [14]	FITCEM [14] 6.4 (FIT Security Target Evaluation)	Requirement formulated in 8.3.1.1 with no alteration

Functional testing may be performed following one of the methods below:

Table C.2 — TR_PID functional testing methods

Assessment method	Specific assessment tasks	Specific technical requirement
SESIP [11]	SESIP [11] 7.6.4 ("ATE_IND.SESIP")	As identified in input verification
CC-3 [13]	CC-3 [13] 12.2.4 Table 162 ("Labelling of the TOE (ALC_CMC.1)" – ALC_CMC.1.1.E)	Covered by assessment task.
FITCEM [14]	FITCEM [14] 6.7 (Conformance testing)	As identified in input verification

Resistance testing may be performed following one of the methods below:

Table C.3 — TR_PID resistance testing methods

Assessment method	Specific assessment tasks	Specific technical requirement
SESIP [11]	7.7 ("Vulnerability assessment requirements") at the level corresponding to the applicable platform risk environment aspect (see Clause A.6)	As identified in input verification
CC-2 [12] CC-3 [13]	CC-3 [13] 14.3 ("Vulnerability analysis (AVA_VAN)") at the level corresponding to the applicable platform risk environment aspect (see Clause A.6)	EN 15048-2 does not specify a technical requirement related to the integrity of the platform. However, if the platform identity is identified as an asset with integrity security property, its protection is verified through the assessments of the following technical requirements: security initialization support, secure update of platform, isolation mechanism, tamper-resistance
FITCEM [14]	FITCEM [14] 6.7 at the level corresponding to the applicable platform risk environment aspect (see Clause A.6)	As identified in input verification

C.2.6 TR_PAU Authenticity of platform

Input verification may be performed following one of the methods below:

Table C.4 — TR_PAU input verification methods

Assessment method	Specific assessment tasks	Specific technical requirement
SESIP [11]	SESIP [11] 7.2.5 ("ASE_TSS.SESIP")	SESIP [11] 5.2.4 ("Attestation of platform genuineness"), and optionally SESIP [11] 5.2.6 ("Attestation of platform state")
CC-2 [12] CC-3 [13]	CC-3 [13] 9.8 ("TOE summary specification (ASE_TSS)")	CC-2 [12] 13.6.6 ("Authentication proof of identity (FIA_API)")
FITCEM [14]	FITCEM [14] 6.4 (FIT Security Target Evaluation)	Requirement formulated in 8.3.2.1 with no alteration

Functional testing may be performed following one of the methods below:

Table C.5 — TR_PAU functional testing methods

Assessment method	Specific assessment tasks	Specific technical requirement
SESIP [11]	SESIP [11] 7.6.4 ("ATE_IND.SESIP")	As identified in input verification
CC-2 [12] CC-3 [13]	CC-3 [13] 15.5.1 ("Evaluation of sub-activity (ATE_FUN.1)") or, CC-3 [13] 15.6.2 ("Evaluation of sub-activity (ATE_IND.2)")	As identified in input verification
FITCEM [14]	FITCEM [14] 6.7 (Conformance testing)	As identified in input verification

Resistance testing may be performed following one of the methods below:

Table C.6 — TR_PAU resistance testing methods

Assessment method	Specific assessment tasks	Specific technical requirement
SESIP [11]	7.7 ("Vulnerability assessment requirements") at the level corresponding to the applicable platform risk environment aspect (see Clause A.6)	As identified in input verification
CC-2 [12] CC-3 [13]	CC-3 [13] 14.3 ("Vulnerability analysis (AVA_VAN)") at the level corresponding to the applicable platform risk environment aspect (see Clause A.6)	As identified in input verification
FITCEM [14]	FITCEM [14] 6.7 at the level corresponding to the applicable platform risk environment aspect (see Clause A.6)	As identified in input verification

C.2.7 TR_INI Secure initialisation support

Input verification may be performed following one of the methods below:

Table C.7 — TR_INI input verification methods

Assessment method	Specific assessment tasks	Specific technical requirement
SESIP [11]	SESIP [11] 7.2.5 ("ASE_TSS.SESIP")	SESIP [11] 5.2.5 ("Secure initialization of platform")
CC-2 [12] CC-3 [13]	CC-3 [13] 9.8 ("TOE summary specification (ASE_TSS)")	CC-2 [12] 15.5 ("TSF initialization (FPT_INI)") for integrity and authenticity aspects CC-2 [12] 15.4 ("Fail secure (FPT_FLS)") for failure handling aspect
FITCEM [14]	FITCEM [14] 6.4 (FIT Security Target Evaluation)	Requirement formulated in 8.3.3.1 with no alteration

Functional testing may be performed following one of the methods below:

Table C.8 — TR_INI functional testing methods

Assessment method	Specific assessment tasks	Specific technical requirement
SESIP [11]	SESIP [11] 7.6.4 ("ATE_IND.SESIP")	As identified in input verification
CC-2 [12] CC-3 [13]	CC-3 [13] 15.5.1 ("Evaluation of sub-activity (ATE_FUN.1)") or, CC-3 [13] 15.6.2 ("Evaluation of sub-activity (ATE_IND.2)")	As identified in input verification
FITCEM [14]	FITCEM [14] 6.7 (Conformance testing)	As identified in input verification

Resistance testing may be performed following one of the methods below:

Table C.9 — TR_INI resistance testing methods

Assessment method	Specific assessment tasks	Specific technical requirement
SESIP [11]	7.7 ("Vulnerability assessment requirements") at the level corresponding to the applicable platform risk environment aspect (see Clause A.6)	As identified in input verification
CC-2 [12] CC-3 [13]	CC-3 [13] 14.3 ("Vulnerability analysis (AVA_VAN)") at the level corresponding to the applicable platform risk environment aspect (see Clause A.6)	As identified in input verification
FITCEM [14]	FITCEM [14] 6.7 at the level corresponding to the applicable platform risk environment aspect (see Clause A.6)	As identified in input verification

C.2.8 TR_SUP Secure update of platform

Input verification may be performed following one of the methods below:

1729

Table C.10 — TR_SUP input verification methods

Assessment method	Specific assessment tasks	Specific technical requirement
SESIP [11]	SESIP [11] 7.2.5 (“ASE_TSS.SESIP”)	SESIP [11] 5.3.4 (“ Secure update of platform ”)
CC-2 [12] CC-3 [13]	CC-3 [13] 9.8 (“TOE summary specification (ASE_TSS)”)	<u>For Integrity and authenticity of update package aspect</u> CC-2 [12] 10.4 (“Cryptographic operations (FCS_COP)” for implementation relying on signature verifications Access control specific technical requirements (8.3.8.4.3) for implementation relying on access restrictions <u>For package new version aspect</u> CC-2 [12] 15.8.7 (“FMT_MSA.2 Secure security attributes”) and applicable dependencies for implementation relying on storage of the last applied package update version, to ensure that only secure values are accepted, with “secure value” to be defined to “newer version”, and/or CC-2 [12] 15.15 (“Inter-TSF TSF data consistency (FPT_TDC)” to ensure the correct handling of the version <u>For update failure handling aspect</u> CC-2 [12] 15.4 (“Fail secure (FPT_FLS)” with assigning the “type of failure” to “platform update failure”
FITCEM [14]	FITCEM [14] 6.4 (FIT Security Target Evaluation)	Requirement formulated in 8.3.4.1 with no alteration

1730 Functional testing may be performed following one of the methods below:

1731

Table C.11 — TR_SUP functional testing methods

Assessment method	Specific assessment tasks	Specific technical requirement
SESIP [11]	SESIP [11] 7.6.4 (“ATE_IND.SESIP”)	As identified in input verification
CC-2 [12] CC-3 [13]	CC-3 [13] 15.5.1 (“Evaluation of sub-activity (ATE_FUN.1)”) or, CC-3 [13] 15.6.2 (“Evaluation of sub-activity (ATE_IND.2)”)	As identified in input verification
FITCEM [14]	FITCEM [14] 6.7 (Conformance testing)	As identified in input verification

1732 Resistance testing may be performed following one of the methods below:

Table C.12 — TR_SUP resistance testing methods

Assessment method	Specific assessment tasks	Specific technical requirement
SESIP [11]	7.7 ("Vulnerability assessment requirements") at the level corresponding to the applicable platform risk environment aspect (see Clause A.6)	As identified in input verification
CC-2 [12] CC-3 [13]	CC-3 [13] 14.3 ("Vulnerability analysis (AVA_VAN)") at the level corresponding to the applicable platform risk environment aspect (see Clause A.6)	As identified in input verification
FITCEM [14]	FITCEM [14] 6.7 at the level corresponding to the applicable platform risk environment aspect (see Clause A.6)	As identified in input verification

C.2.9 TR_SUD Secure update of dependent component

Input verification may be performed following one of the methods below:

Table C.13 — TR_SUD input verification methods

Assessment method	Specific assessment tasks	Specific technical requirement
SESIP [11]	SESIP [11] 7.2.5 ("ASE_TSS.SESIP")	SESIP [11] 5.3.5 ("Secure update of application")
CC-2 [12] CC-3 [13]	CC-3 [13] 9.8 ("TOE summary specification (ASE_TSS)")	CC-2 [12] 10.4 ("Cryptographic operations (FCS_COP)") for implementation relying on signature verifications Access control specific technical requirements (8.3.8.4.3) for implementation relying on access restrictions
FITCEM [14]	FITCEM [14] 6.4 (FIT Security Target Evaluation)	Requirement formulated in 8.3.5.1 with no alteration

Functional testing may be performed following one of the methods below:

Table C.14 — TR_SUD functional testing methods

Assessment method	Specific assessment tasks	Specific technical requirement
SESIP [11]	SESIP [11] 7.6.4 ("ATE_IND.SESIP")	As identified in input verification
CC-2 [12] CC-3 [13]	CC-3 [13] 15.5.1 ("Evaluation of sub-activity (ATE_FUN.1)") or, CC-3 [13] 15.6.2 ("Evaluation of sub-activity (ATE_IND.2)")	As identified in input verification
FITCEM [14]	FITCEM [14] 6.7 (Conformance testing)	As identified in input verification

Resistance testing may be performed following one of the methods below:

1740

Table C.15 — TR_SUD resistance testing methods

Assessment method	Specific assessment tasks	Specific technical requirement
SESIP [11]	7.7 ("Vulnerability assessment requirements") at the level corresponding to the applicable platform risk environment aspect (see Clause A.6)	As identified in input verification
CC-2 [12] CC-3 [13]	CC-3 [13] 14,3 ("Vulnerability analysis (AVA_VAN)") at the level corresponding to the applicable platform risk environment aspect (see Clause A.6)	As identified in input verification
FITCEM [14]	FITCEM [14] 6.7 at the level corresponding to the applicable platform risk environment aspect (see Clause A.6)	As identified in input verification

1741 **C.2.10 TR_ERA Secure erasure of data**

1742 Input verification may be performed following one of the methods below:

1743 **Table C.16 — TR_ERA input verification methods**

Assessment method	Specific assessment tasks	Specific technical requirement
SESIP [11]	SESIP [11] 7.2.5 ("ASE_TSS.SESIP")	SESIP [11] 5.7.6 (" Residual information purging ")
CC-2 [12] CC-3 [13]	CC-3 [13] 9.8 ("TOE summary specification (ASE_TSS)")	CC-2 [12] 13.9 ("Specification of Management Functions (FMT_SMF)") with assignment of secure data erasure function CC-2 [12] 11.12 ("Residual information protection (FDP_RIP)") with selection of the deallocation of the resource event CC-2 [12] 10.3.11 ("FCS_CKM.6 Timing and event of cryptographic key destruction")
FITCEM [14]	FITCEM [14] 6.4 (FIT Security Target Evaluation)	Requirement formulated in 8.3.6.1 with no alteration

1744 Functional testing may be performed following one of the methods below:

1745 **Table C.17 — TR_ERA functional testing methods**

Assessment method	Specific assessment tasks	Specific technical requirement
SESIP [11]	SESIP [11] 7.6.4 ("ATE_IND.SESIP")	As identified in input verification
CC-2 [12] CC-3 [13]	CC-3 [13] 15.5.1 ("Evaluation of sub-activity (ATE_FUN.1)") or, CC-3 [13] 15.6.2 ("Evaluation of sub-activity (ATE_IND.2)")	As identified in input verification
FITCEM [14]	FITCEM [14] 6.7 (Conformance testing)	As identified in input verification

1746 Resistance testing may be performed following one of the methods below:

Table C.18 — TR_ERA resistance testing methods

Assessment method	Specific assessment tasks	Specific technical requirement
SESIP [11]	7.7 ("Vulnerability assessment requirements") at the level corresponding to the applicable platform risk environment aspect (see Clause A.6)	As identified in input verification
CC-2 [12] CC-3 [13]	CC-3 [13] 14.3 ("Vulnerability analysis (AVA_VAN)") at the level corresponding to the applicable platform risk environment aspect (see Clause A.6)	As identified in input verification
FITCEM [14]	FITCEM [14] 6.7 at the level corresponding to the applicable platform risk environment aspect (see Clause A.6)	As identified in input verification

C.2.11 TR_ISO Isolation mechanisms

Input verification may be performed following one of the methods below:

Table C.19 — TR_ISO input verification methods

Assessment method	Specific assessment tasks	Specific technical requirement
SESIP [11]	SESIP [11] 7.2.5 ("ASE_TSS.SESIP")	SESIP [11] 5.5.4 ("Software attacker resistance: isolation of platform"), and/or SESIP [11] 5.5.5 ("Software attacker resistance: isolation of platform parts"), and/or SESIP [11] 5.5.6 (" Software attacker resistance: isolation of applications parts ")
CC-2 [12] CC-3 [13]	CC-3 [13] 9.8 ("TOE summary specification (ASE_TSS)")	CC-2 [12] 11.7 ("Information flow control policy (FDP_IFC)") to specify the authorized information flows platform resources, and CC-2 [12] 11.8 ("Information flow control functions (FDP_IFF)") to specify on which attributes the information flows is authorized.
FITCEM [14]	FITCEM [14] 6.4 (FIT Security Target Evaluation)	Requirement formulated in 8.3.7.1 with no alteration

Functional testing may be performed following one of the methods below:

Table C.20 — TR_ISO functional testing methods

Assessment method	Specific assessment tasks	Specific technical requirement
SESIP [11]	SESIP [11] 7.6.4 ("ATE_IND.SESIP")	As identified in input verification
CC-2 [12] CC-3 [13]	CC-3 [13] 15.5.1 ("Evaluation of sub-activity (ATE_FUN.1)") or, CC-3 [13] 15.6.2 ("Evaluation of sub-activity (ATE_IND.2)")	As identified in input verification

Assessment method	Specific assessment tasks	Specific technical requirement
FITCEM [14]	FITCEM [14] 6.7 (Conformance testing)	As identified in input verification

1753 Resistance testing may be performed following one of the methods below:

1754 **Table C.21 — TR_ISO resistance testing methods**

Assessment method	Specific assessment tasks	Specific technical requirement
SESIP [11]	7.7 ("Vulnerability assessment requirements") at the level corresponding to the applicable platform risk environment aspect (see Clause A.6)	As identified in input verification
CC-2 [12] CC-3 [13]	CC-3 [13] 14.3 ("Vulnerability analysis (AVA_VAN)") at the level corresponding to the applicable platform risk environment aspect (see Clause A.6)	As identified in input verification
FITCEM [14]	FITCEM [14] 6.7 at the level corresponding to the applicable platform risk environment aspect (see Clause A.6)	As identified in input verification

1755 **C.2.12 TR_ACC Access control to security functionalities**

1756 Input verification may be performed following one of the methods below:

1757 **Table C.22 — TR_ACC input verification methods**

Assessment method	Specific assessment tasks	Specific technical requirement
SESIP [11]	SESIP [11] 7.2.5 ("ASE_TSS.SESIP")	SESIP [11] 5.8.2 ("Privileged access control"), and/or SESIP [11] 5.8.3 (" Authenticated access control ")
CC-2 [12] CC-3 [13]	CC-3 [13] 9.8 ("TOE summary specification (ASE_TSS)")	For signature verification scenario: — CC-2 [12] 12.8 ("User identification (FIA_UID)"), and — CC-2 [12] 12.7 ("User identification (FIA_UAU)"), and — CC-2 [12] 10.4 ("Cryptographic operations (FCS_COP)") For trusted path scenario: — CC-2 [12] 12.8 ("User identification (FIA_UID)"), and — CC-2 [12] 12.7 ("User identification (FIA_UAU)"), and — CC-2 [12] 11.7 ("Information flow control policy (FDP_IFC)"), and — CC-2 [12] 11.8 ("Information flow control functions (FDP_IFF)") For privileged roles or element of context scenarios:

Assessment method	Specific assessment tasks	Specific technical requirement
		— CC-2 [12] 12.8 (“User identification (FIA_UID)”), and — CC-2 [12] 13.10 (“Security management roles (FMT_SMR)”), and — CC-2 [12] 13.5 (“Management of security attributes (FMT_MSA)”), and/or — CC-2 [12] 13.6 (“Management of TSF data (FMT_MTD)”)
FITCEM [14]	FITCEM [14] 6.4 (FIT Security Target Evaluation)	Requirement formulated in 8.3.8.1 with no alteration

Functional testing may be performed following one of the methods below:

Table C.23 — TR_ACC functional testing methods

Assessment method	Specific assessment tasks	Specific technical requirement
SESIP [11]	SESIP [11] 7.6.4 (“ATE_IND.SESIP”)	As identified in input verification
CC-2 [12] CC-3 [13]	CC-3 [13] 15.5.1 (“Evaluation of sub-activity (ATE_FUN.1)”) or, CC-3 [13] 15.6.2 (“Evaluation of sub-activity (ATE_IND.2)”)	As identified in input verification
FITCEM [14]	FITCEM [14] 6.7 (Conformance testing)	As identified in input verification

Resistance testing may be performed following one of the methods below:

Table C.24 — TR_ACC resistance testing methods

Assessment method	Specific assessment tasks	Specific technical requirement
SESIP [11]	7.7 (“Vulnerability assessment requirements”) at the level corresponding to the applicable platform risk environment aspect (see Clause A.6)	As identified in input verification
CC-2 [12] CC-3 [13]	CC-3 [13] 14.3 (“Vulnerability analysis (AVA_VAN)”) at the level corresponding to the applicable platform risk environment aspect (see Clause A.6)	As identified in input verification
FITCEM [14]	FITCEM [14] 6.7 at the level corresponding to the applicable platform risk environment aspect (see Clause A.6)	As identified in input verification

C.2.13 TR_STO Secure storage

Input verification may be performed following one of the methods below:

1764

Table C.25 — TR_STO input verification methods

Assessment method	Specific assessment tasks	Specific technical requirement
SESIP [11]	SESIP [11] 7.2.5 ("ASE_TSS.SESIP")	SESIP [11] 5.7.2 ("Secure trusted storage") where integrity and authenticity are required SESIP [11] 5.7.3 ("Secure confidential storage") where confidentiality, integrity and authenticity are required SESIP [11] 5.7.2 ("Secure encrypted storage") where confidentiality, integrity and authenticity based on cryptography is required SESIP [11] 5.7.2 ("Secure data serialization") where encryption is required for storage out of the platform control
CC-2 [12] CC-3 [13]	CC-3 [13] 9.8 ("TOE summary specification (ASE_TSS)")	CC-2 [12] 11.14 ("Stored data confidentiality (FDP_SDC)") where confidentiality is required CC-2 [12] 11.15 ("Stored data integrity (FDP_SDI)") where integrity is required CC-2 [12] 11.5 ("Data authentication (FDP_DAU)") where authenticity is required CC-2 [12] 10.4 ("Cryptographic operations (FCS_COP)") where cryptography is involved
FITCEM [14]	FITCEM [14] 6.4 (FIT Security Target Evaluation)	Requirement formulated in 8.3.9.1 with no alteration

1765 Functional testing may be performed following one of the methods below:

1766

Table C.26 — TR_STO functional testing methods

Assessment method	Specific assessment tasks	Specific technical requirement
SESIP [11]	SESIP [11] 7.6.4 ("ATE_IND.SESIP")	As identified in input verification
CC-2 [12] CC-3 [13]	CC-3 [13] 15.5.1 ("Evaluation of sub-activity (ATE_FUN.1)") or, CC-3 [13] 15.6.2 ("Evaluation of sub-activity (ATE_IND.2)")	As identified in input verification
FITCEM [14]	FITCEM [14] 6.7 (Conformance testing)	As identified in input verification

1767 Resistance testing may be performed following one of the methods below:

Table C.27 — TR_STO resistance testing methods

Assessment method	Specific assessment tasks	Specific technical requirement
SESIP [11]	7.7 ("Vulnerability assessment requirements") at the level corresponding to the applicable platform risk environment aspect (see Clause A.6)	As identified in input verification
CC-2 [12] CC-3 [13]	CC-3 [13] 14.3 ("Vulnerability analysis (AVA_VAN)") at the level corresponding to the applicable platform risk environment aspect (see Clause A.6)	As identified in input verification
FITCEM [14]	FITCEM [14] 6.7 at the level corresponding to the applicable platform risk environment aspect (see Clause A.6)	As identified in input verification

C.2.14 TR_COM Secure communication

Input verification may be performed following one of the methods below:

Table C.28 — TR_COM input verification methods

Assessment method	Specific assessment tasks	Specific technical requirement
SESIP [11]	SESIP [11] 7.2.5 ("ASE_TSS.SESIP")	SESIP [11] 5.4.2 ("Secure communication support") SESIP [11] 5.4.3 (" Secure communication enforcement ")
CC-2 [12] CC-3 [13]	CC-3 [13] 9.8 ("TOE summary specification (ASE_TSS)")	For exchanges of user sensitive data with untrusted entity: CC-2 [12] 11.6 (Export from the TOE (FDP_ETC)) and CC-2 [12] 11.10 (Import from outside the TOE (FDP_ITC)) and their applicable dependencies For exchanges of sensitive data with trusted entity: CC-2 [12] 18.3 (Inter-TSF trusted channel (FTP_ITC)) or CC-2 [12] 18.5 (Trusted path (FTP_TRP)), and — for user data: CC-2 [12] 11.16 (Inter-TSF user data confidentiality transfer protection (FDP_UCT)) and CC-2 [12] 11.17 (Inter-TSF user data integrity transfer protection (FDP_UIT)) and their applicable dependencies — for non-user sensitive data: CC-2 [12] 15.7 (Confidentiality of exported TSF data (FPT_ITC)) if confidentiality is required and CC-2 [12] 15.8 (Integrity of exported TSF data (FPT_ITI)) if confidentiality is required

Assessment method	Specific assessment tasks	Specific technical requirement
		Additionally, in any case CC-2 [12] 10.4 ("Cryptographic operations (FCS_COP)") for cryptographic operations.
FITCEM [14]	FITCEM [14] 6.4 (FIT Security Target Evaluation)	Requirement formulated in 8.3.10.1 with no alteration

1772 Functional testing may be performed following one of the methods below:

1773 **Table C.29 — TR_COM functional testing methods**

Assessment method	Specific assessment tasks	Specific technical requirement
SESIP [11]	SESIP [11] 7.6.4 ("ATE_IND.SESIP")	As identified in input verification
CC-2 [12] CC-3 [13]	CC-3 [13] 15.5.1 ("Evaluation of sub-activity (ATE_FUN.1)") or, CC-3 [13] 15.6.2 ("Evaluation of sub-activity (ATE_IND.2)")	As identified in input verification
FITCEM [14]	FITCEM [14] 6.7 (Conformance testing)	As identified in input verification

1774 Resistance testing may be performed following one of the methods below:

1775 **Table C.30 — TR_COM resistance testing methods**

Assessment method	Specific assessment tasks	Specific technical requirement
SESIP [11]	7.7 ("Vulnerability assessment requirements") at the level corresponding to the applicable platform risk environment aspect (see Clause A.6)	As identified in input verification
CC-2 [12] CC-3 [13]	CC-3 [13] 14.3 ("Vulnerability analysis (AVA_VAN)") at the level corresponding to the applicable platform risk environment aspect (see Clause A.6)	As identified in input verification
FITCEM [14]	FITCEM [14] 6.7 at the level corresponding to the applicable platform risk environment aspect (see Clause A.6)	As identified in input verification

1776 **C.2.15 TR_CRY Secure cryptographic features**

1777 Input verification may be performed following one of the methods below:

1778 **Table C.31 — TR_CRY input verification methods**

Assessment method	Specific assessment tasks	Specific technical requirement
SESIP [11]	SESIP [11] 7.2.5 ("ASE_TSS.SESIP")	SESIP [11] 5.6.2 ("Cryptographic operations"), and/or SESIP [11] 5.6.3 ("Cryptographic key generation"), and/or SESIP [11] 5.6.4 ("Cryptographic keyStore"), and/or

Assessment method	Specific assessment tasks	Specific technical requirement
		SESIP [11] 5.6.5 (“ Cryptographic random number generation ”), and/or
CC-2 [12] CC-3 [13]	CC-3 [13] 9.8 (“TOE summary specification (ASE_TSS)”)	CC-2 [12] 10.3 (“Cryptographic key management (FCS_CKM)”) CC-2 [12] 10.4 (“Cryptographic operations (FCS_COP)”) CC-2 [12] 10.5 (“Random bit generation (FCS_RBG)”) CC-2 [12] 10.6 (“Generation of random numbers (FCS_RNG)”)
FITCEM [14]	FITCEM [14] 6.4 (FIT Security Target Evaluation)	Requirement formulated in 8.3.11.1 with no alteration

Functional testing may be performed following one of the methods below:

Table C.32 — TR_CRY functional testing methods

Assessment method	Specific assessment tasks	Specific technical requirement
SESIP [11]	SESIP [11] 7.6.4 (“ATE_IND.SESIP”)	As identified in input verification
CC-2 [12] CC-3 [13]	CC-3 [13] 15.5.1 (“Evaluation of sub-activity (ATE_FUN.1)”) or, CC-3 [13] 15.6.2 (“Evaluation of sub-activity (ATE_IND.2)”)	As identified in input verification
FITCEM [14]	FITCEM [14] 6.7 (Conformance testing)	As identified in input verification

Resistance testing may be performed following one of the methods below:

Table C.33 — TR_CRY resistance testing methods

Assessment method	Specific assessment tasks	Specific technical requirement
SESIP [11]	7.7 (“Vulnerability assessment requirements”) at the level corresponding to the applicable platform risk environment aspect (see Clause A.6)	As identified in input verification
CC-2 [12] CC-3 [13]	CC-3 [13] 14.3 (“Vulnerability analysis (AVA_VAN)”) at the level corresponding to the applicable platform risk environment aspect (see Clause A.6)	As identified in input verification
FITCEM [14]	FITCEM [14] 6.7 at the level corresponding to the applicable platform risk environment aspect (see Clause A.6)	As identified in input verification

C.2.16 TR_REP Reporting of security events

Input verification may be performed following one of the methods below:

1785

Table C.34 — TR_REP input verification methods

Assessment method	Specific assessment tasks	Specific technical requirement
SESIP [11]	SESIP [11] 7.2.5 ("ASE_TSS.SESIP")	SESIP [11] 5.7.7 ("Audit log generation and storage")
CC-2 [12] CC-3 [13]	CC-3 [13] 9.8 ("TOE summary specification (ASE_TSS)")	CC-2 [12] 8.4 ("Security audit data generation (FAU_GEN)") and applicable dependencies CC-2 [12] 8.4 ("Security audit data storage (FAU_STG)") and applicable dependencies
FITCEM [14]	FITCEM [14] 6.4 (FIT Security Target Evaluation)	Requirement formulated in 8.3.12.1 with no alteration

1786 Functional testing may be performed following one of the methods below:

1787

Table C.35 — TR_REP functional testing methods

Assessment method	Specific assessment tasks	Specific technical requirement
SESIP [11]	SESIP [11] 7.6.4 ("ATE_IND.SESIP")	As identified in input verification
CC-2 [12] CC-3 [13]	CC-3 [13] 15.5.1 ("Evaluation of sub-activity (ATE_FUN.1)") or, CC-3 [13] 15.6.2 ("Evaluation of sub-activity (ATE_IND.2)")	As identified in input verification
FITCEM [14]	FITCEM [14] 6.7 (Conformance testing)	As identified in input verification

1788 Resistance testing may be performed following one of the methods below:

1789

Table C.36 — TR_REP resistance testing methods

Assessment method	Specific assessment tasks	Specific technical requirement
SESIP [11]	7.7 ("Vulnerability assessment requirements") at the level corresponding to the applicable platform risk environment aspect (see Clause A.6)	As identified in input verification
CC-2 [12] CC-3 [13]	CC-3 [13] 14.3 ("Vulnerability analysis (AVA_VAN)") at the level corresponding to the applicable platform risk environment aspect (see Clause A.6)	As identified in input verification
FITCEM [14]	FITCEM [14] 6.7 at the level corresponding to the applicable platform risk environment aspect (see Clause A.6)	As identified in input verification

1790 C.2.17 TR_AVS Advanced availability support of basic and essential functions

1791 Input verification may be performed following one of the methods below:

Table C.37 — TR_AVS input verification methods

Assessment method	Specific assessment tasks	Specific technical requirement
SESIP [11]	SESIP [11] 7.2.5 ("ASE_TSS.SESIP")	SESIP [11] 5.9.3 ("Availability support")
CC-2 [12] CC-3 [13]	CC-3 [13] 9.8 ("TOE summary specification (ASE_TSS)")	CC-2 [12] 15.4 ("Fail secure (FLT_FLS)") CC-2 [12] 16.3 ("Fault tolerance (FRU_FLT)")
FITCEM [14]	FITCEM [14] 6.4 (FIT Security Target Evaluation)	Requirement formulated in 8.3.13.1 with no alteration

Functional testing may be performed following one of the methods below:

Table C.38 — TR_AVS functional testing methods

Assessment method	Specific assessment tasks	Specific technical requirement
SESIP [11]	SESIP [11] 7.6.4 ("ATE_IND.SESIP")	As identified in input verification
CC-2 [12] CC-3 [13]	CC-3 [13] 15.5.1 ("Evaluation of sub-activity (ATE_FUN.1)") or, CC-3 [13] 15.6.2 ("Evaluation of sub-activity (ATE_IND.2)")	As identified in input verification
FITCEM [14]	FITCEM [14] 6.7 (Conformance testing)	As identified in input verification

Resistance testing may be performed following one of the methods below:

Table C.39 — TR_AVS resistance testing methods

Assessment method	Specific assessment tasks	Specific technical requirement
SESIP [11]	7.7 ("Vulnerability assessment requirements") at the level corresponding to the applicable platform risk environment aspect (see Clause A.6)	As identified in input verification
CC-2 [12] CC-3 [13]	CC-3 [13] 14.3 ("Vulnerability analysis (AVA_VAN)") at the level corresponding to the applicable platform risk environment aspect (see Clause A.6)	As identified in input verification
FITCEM [14]	FITCEM [14] 6.7 at the level corresponding to the applicable platform risk environment aspect (see Clause A.6)	As identified in input verification

C.2.18 TR_RST Reset of platform to initial state

Input verification may be performed following one of the methods below:

Table C.40 — TR_RST input verification methods

Assessment method	Specific assessment tasks	Specific technical requirement
SESIP [11]	SESIP [11] 7.2.5 ("ASE_TSS.SESIP")	SESIP [11] 5.3.2 ("Factory reset of platform")

Assessment method	Specific assessment tasks	Specific technical requirement
CC-3 [13]	CC-3 [13] 9.8 ("TOE summary specification (ASE_TSS)")	EN 15048-2 does not specify any technical requirement related to resetting the platform to an initial secure state. However, such requirement may be defined in compliance with CC-3 [13] 7.6 ("Extended component definition (ASE_ECD)")
FITCEM [14]	FITCEM [14] 6.4 (FIT Security Target Evaluation)	Requirement formulated in 8.3.14.1 with no alteration

1800 Functional testing may be performed following one of the methods below:

1801 **Table C.41 — TR_RST functional testing methods**

Assessment method	Specific assessment tasks	Specific technical requirement
SESIP [11]	SESIP [11] 7.6.4 ("ATE_IND.SESIP")	As identified in input verification
CC-3 [13]	CC-3 [13] 15.5.1 ("Evaluation of sub-activity (ATE_FUN.1)") or, CC-3 [13] 15.6.2 ("Evaluation of sub-activity (ATE_IND.2)")	As identified in input verification
FITCEM [14]	FITCEM [14] 6.7 (Conformance testing)	As identified in input verification

1802 Resistance testing may be performed following one of the methods below:

1803 **Table C.42 — TR_RST resistance testing methods**

Assessment method	Specific assessment tasks	Specific technical requirement
SESIP [11]	7.7 ("Vulnerability assessment requirements") at the level corresponding to the applicable platform risk environment aspect (see Clause A.6)	As identified in input verification
CC-3 [13]	CC-3 [13] 14.3 ("Vulnerability analysis (AVA_VAN)") at the level corresponding to the applicable platform risk environment aspect (see Clause A.6)	As identified in input verification
FITCEM [14]	FITCEM [14] 6.7 at the level corresponding to the applicable platform risk environment aspect (see Clause A.6)	As identified in input verification

1804 **C.2.19 TR_RES Tamper resistance of platform**

1805 Input verification may be performed following one of the methods below:

1806 **Table C.43 — TR_RES input verification methods**

Assessment method	Specific assessment tasks	Specific technical requirement
SESIP [11]	SESIP [11] 7.2.5 ("ASE_TSS.SESIP")	SESIP [11] 5.5.2 ("Limited physical attacker resistance") or SESIP [11] 5.5.3 ("Physical attacker resistance")

prEN 50766:2026 (E)

Assessment method	Specific assessment tasks	Specific technical requirement
CC-2 [12] CC-3 [13]	CC-3 [13] 9.8 ("TOE summary specification (ASE_TSS)")	CC-2 [12] 14.6 ("Unobservability (FPR_UNO)") CC-2 [12] 15.10.8 ("FPT_PHP.3 (Resistance to physical attack)")
FITCEM [14]	FITCEM [14] 6.4 (FIT Security Target Evaluation)	Requirement formulated in 8.3.15.1 with no alteration

Functional testing is demonstrated through input and resistance verifications.

Resistance testing may be performed following one of the methods below:

Table C.44 — TR_RES resistance testing methods

Assessment method	Specific assessment tasks	Specific technical requirement
SESIP [11]	7.7 ("Vulnerability assessment requirements") at the level corresponding to the applicable platform risk environment aspect (see Clause A.6)	As identified in input verification
CC-2 [12] CC-3 [13]	CC-3 [13] 14.3 ("Vulnerability analysis (AVA_VAN)") at the level corresponding to the applicable platform risk environment aspect (see Clause A.6)	As identified in input verification
FITCEM [14]	FITCEM [14] 6.7 (Conformance testing) at the level corresponding to the applicable platform risk environment aspect (see Clause A.6)	As identified in input verification

C.2.20 TR_SEG Application of platform security guidance

Input verification may be performed following one of the methods below:

Table C.45 — TR_SEG input verification methods

Assessment method	Specific assessment tasks	Specific technical requirement
SESIP [11]	SESIP [11] 7.3 ("Guidance documents requirements")	N/A
CC-3 [13]	CC-3 [13] 11 ("Class AGD Guidance documents")	N/A
FITCEM [14]	FITCEM [14] 6.6 (Evaluation of TOE installation)	N/A

Functional testing is not applicable.

Resistance testing is not applicable.

C.3 SESIP profiles analysis of compliance support

Table C.46 below analyses the coverage of the technical requirements of this document SESIP profiles. This provides guidelines for the reuse of SESIP evaluations results against those profiles.

1818

Table C.46 — Platform categories and applicability overview

Platform category	Applicable technical requirements	Applicability	SESIP profile [8]	SESIP profile [9]	SESIP profile [10]
PTF-COR	TR_VUL Vulnerability handling process	Mandatory with no exception	Partially covered by 4.1.1 ALC_FLR.2	Partially covered by 5.1.1 ALC_FLR.2	Partially covered by 5.1.1 ALC_FLR.2
PTF-COR	TR_IMP Implementation best practices	Mandatory with exception in case of organizational constraints	Covered by assessment of technical requirements from 4	Covered by assessment of technical requirements from 4	Covered by assessment of technical requirements from 4
PTF-COR	TR_EXP No known exploitable vulnerabilities	Mandatory with no exception	Covered by assessment of technical requirements from 4	Covered by assessment of technical requirements from 4	Covered by assessment of technical requirements from 4
PTF-COR	TR_CFG Secure configuration of platform	Mandatory , with exception in case protections are covered by organizational measures	Covered by assessment of technical requirements from 4	Covered by assessment of technical requirements from 4	Covered by assessment of technical requirements from 4
PTF-COR	TR_PID Identification of platform	Mandatory with no exception	4.2.1 – all aspects covered Mandatory with no exception	5.2.1 / 5.2.2 – all aspects covered Mandatory with no exception	5.2.1 / 5.2.2 – all aspects covered Mandatory with no exception
PTF-COR	TR_INI Secure initialisation support	Mandatory , with exception in case of technical limitations	4.2.2 – all aspects covered Mandatory with exception for hardware only; compliant with TR_INI implementation options	5.2.4 – all aspects covered Mandatory with no exception	5.2.4 – all aspects covered Mandatory with no exception
PTF-COR	TR_SUP Secure update of platform	Mandatory , with exception in case of design limitations and technical limitations	4.2.3 – all aspects covered Mandatory with exceptions to be justified; compliant with TR_SUP applicability exceptions	5.2.6 – all aspects covered Mandatory with no exception	5.2.6 – all aspects covered Mandatory with no exception
PTF-COR	TR_SUD Secure	Mandatory if dependent	Optional package 4.8 – all aspects	Optional package 5.3 - all aspects	Optional package 5.3 - all aspects

prEN 50766:2026 (E)

	update of dependent components	components are to be run on the platform, with possible delegation	covered with adding of SESIP SFR "Secure update of application" ([11] 5.3.5) for platforms aiming at running customers dependent components	covered with adding of SESIP SFR "Secure update of application" ([11] 5.3.5) for platforms aiming at running customers dependent components	covered with adding of SESIP SFR "Secure update of application" ([11] 5.3.5) for platforms aiming at running customers dependent components
PTF-COR	TR_ERA Secure erasure of data	Mandatory , with exception in case no confidential data, or technical limitation	4.2.1 – all aspects covered Mandatory with no exception	Optional package 5.3 - all aspects covered with adding of SESIP SFR "Residual information purging" ([11] 5.7.6)	Optional package 5.3 - all aspects covered with adding of SESIP SFR "Residual information purging" ([11] 5.7.6)
PTF-COR	TR_ISO Isolation mechanisms – between the platform and its environment	Mandatory, with exception in case the platform is intended to be operated in trusted logical environment (ENV-TRL)	4.4.1 – all aspects covered Mandatory in configuration [any code] equivalent to ENV-NTL; compliant	5.2.7 / 5.2.8 – all aspects covered Mandatory with no exception	5.2.8 / 5.2.9 – all aspects covered Mandatory with no exception
PTF-MTR	TR_RES Tamper-resistance of platform	Mandatory Protections against logical attacks for all platforms. Protection against physical attacks for platforms in ENV-NTP	For resistance to logical attacks mandatory in SESIP evaluation For resistance to physical attacks: 4.5.1 Mandatory in configuration [any user] equivalent to ENV-NTP; compliant	Optional package 5.3.8 – all aspects covered	For resistance to logical attacks mandatory in SESIP evaluation For resistance to physical attacks: 5.2.7 Mandatory with no exception
PTF-ADV	TR_ISO Isolation mechanisms – between parts of the platform and/or between dependent components dedicated resources	According to risk assessment and aligned with platform claimed security capabilities	For isolation <u>between platform parts</u> : Optional package 4.8 - all aspects covered with adding of SESIP SFR "Software attacker resistance: Isolation of platform parts" ([11] 5.5.5) For isolation <u>between</u>	For isolation <u>between platform parts</u> : Optional package 5.3 - all aspects covered with adding of SESIP SFR "Software attacker resistance: Isolation of platform parts" ([11] 5.5.5) For isolation <u>between</u>	For isolation <u>between platform parts</u> : Optional package 5.3 - all aspects covered with adding of SESIP SFR "Software attacker resistance: Isolation of platform parts" ([11] 5.5.5) For isolation <u>between</u>

			<u>dependent components:</u> Optional package 4.8 - all aspects covered with adding of SESIP SFR "Software attacker resistance: Isolation of application parts" ([11] 5.5.6)	<u>dependent components:</u> 5.3.2 – all aspects covered	<u>dependent components:</u> 4.3.2 – all aspects covered
	TR_ACC Access control to security functionalities	According to risk assessment and aligned with platform claimed security capabilities	4.2.5 - all aspects covered Mandatory if functionality available NOTE Secure debugging is the only functionality with mandatory access restriction in this profile. Additional access restrictions can be claimed with Optional package 4.8 adding of SESIP SFR "Privileged access control" ([11] 5.8.2) and/or "Authenticated access control" ([11] 5.8.3)	Optional package 5.3 - all aspects covered with selection of 5.3.3 (Secure debugging is the only functionality with mandatory access restriction) NOTE Secure debugging is the only functionality with mandatory access restriction in this profile. Additional access restrictions can be claimed with Optional package 5.6 adding of SESIP SFR "Privileged access control" ([11] 5.8.2) and/or "Authenticated access control" ([11] 5.8.3)	Optional package 5.3 - all aspects covered with selection of 5.3.3 (Secure debugging is the only functionality with mandatory access restriction) NOTE Secure debugging is the only functionality with mandatory access restriction in this profile. Additional access restrictions can be claimed with Optional package 5.6 adding of SESIP SFR "Privileged access control" ([11] 5.8.2) and/or "Authenticated access control" ([11] 5.8.3)
	TR_AVS Advanced availability support of basic and essential functions	According to risk assessment and aligned with platform claimed security capabilities	Optional package 4.8 - all aspects covered with adding of SESIP SFR "Availability support" ([11] 5.9.3)	Optional package 5.3 - all aspects covered with adding of SESIP SFR "Availability support" ([11] 5.9.3)	Optional package 5.3 - all aspects covered with adding of SESIP SFR "Availability support" ([11] 5.9.3)
Security services PTF-SER	TR_PAU Authentication of platform	According to risk assessment and aligned with platform claimed security capabilities	Optional package 4.8 - all aspects covered with adding of SESIP SFR "Attestation of platform genuineness" ([11] 5.2.4)	5.2.3 – all aspects covered Mandatory with no exception	5.2.3 – all aspects covered Mandatory with no exception

TR_STO Secure storage	According to risk assessment and aligned with platform claimed security capabilities	Optional package 4.7 – all aspects covered with selection of 4.7.1 and/or 4.7.2 and/or 4.7.3 and/or 4.7.4	Optional package 5.3 – all aspects covered with selection of 5.3.3 and/or 5.3.4 and/or 5.3.5 and/or 5.3.7	Optional package 5.3 – all aspects covered with selection of 5.3.4 and/or 5.3.5 and/or 5.3.6 and/or 5.3.7	
TR_COM Secure communication	According to risk assessment and aligned with platform claimed security capabilities Mandatory when processing data remotely	Optional package 4.8 - all aspects covered with adding of SESIP SFR “Secure communication support” ([11] 5.4.2) and/or “Secure communication enforcement” ([11] 5.4.3)	Optional package 5.3 – all aspects covered with selection of 5.3.1 and/or 5.3.2	Optional package 5.3 – all aspects covered with selection of 4.3.4 and/or 4.3.5 and/or 4.3.6 and/or 4.3.7	
TR_CRY Secure cryptographic features	According to risk assessment and aligned with platform claimed security capabilities	Optional package 4.3 – all aspects covered with selection of 4.3.1 and/or 4.3.2 and/or 4.3.3 and/or 4.3.4	5.2.9 / 5.2.10 / 5.2.11 / 5.2.12 – all aspects covered Mandatory with no exception	5.2.10 / 5.2.11 / 5.2.12 / 5.2.13– all aspects covered Mandatory with no exception	
TR_REP Reporting of security events	According to risk assessment and aligned with platform claimed security capabilities	Optional package 4.8 - all aspects covered with adding of SESIP SFR “Audit log generation and storage” ([11] 5.7.7)	Optional package 5.3 – all aspects covered with selection of 5.3.1	Optional package 5.3 – all aspects covered with selection of 5.3.1	
SRD_RST Reset of platform to initial state	According to risk assessment and aligned with platform claimed security capabilities	Optional package 4.8 - all aspects covered with adding of SESIP SFR “Factory reset of platform” ([11] 5.3.2)	Optional package 5.3 - all aspects covered with adding of SESIP SFR “Factory reset of platform” ([11] 5.3.2)	Optional package 5.3 - all aspects covered with adding of SESIP SFR “Factory reset of platform” ([11] 5.3.2)	

Annex ZZ (informative)

Relationship between this European Standard and the essential requirements of Regulation (EU) 2024/2847 aimed to be covered

This European Standard has been prepared under a Commission's standardization request M/606 – C(2025)618¹ to provide one voluntary means of conforming to essential requirements of Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) No 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act).

Once this standard is cited in the Official Journal of the European Union under that Regulation, compliance with the normative clauses of this standard given in Table ZZ.1 confers, within the limits of the scope of this standard, a presumption of conformity with the corresponding essential requirements of that Regulation, and associated EFTA regulations.

Where a definition in this standard differs from a definition of the same term set out in Regulation (EU) 2024/2847, the differences shall be indicated in this Annex Z. Where a reference from a clause of this standard to risk assessment is made, the risk assessment process needs to be in compliance with Regulation (EU) 2024/2847. For the purpose of using this standard in support of the requirements set out in Regulation (EU) 2024/2847, the definitions set out in the Regulation prevail.

Table ZZ.1 — Correspondence between this European Standard and Annex I of Regulation (EU) 2024/2847

Essential Requirements of Regulation (EU) 2024/2847	Clause(s) / subclause(s) of this EN	Remarks / Notes
Part I, (1)	Clause 8	
Part I, (2).(a)	8.2.2	
Part I, (2).(b)	8.2.3 8.3.6 8.3.14 8.4.1	
Part I, (2).(c)	8.3.4 8.3.5	
Part I, (2).(d)	8.3.7 8.3.8 8.3.12 8.3.15	
Part I, (2).(e)	8.3.3 8.3.4 8.3.5	

¹ COMMISSION IMPLEMENTING DECISION of 3.2.2025 on a standardisation request to the European Committee for Standardisation (CEN), the European Committee for Electrotechnical Standardisation (Cenelec) and the European Telecommunications Standards Institute (ETSI) as regards products with digital elements in support of Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act).

prEN 50766:2026 (E)

Essential Requirements of Regulation (EU) 2024/2847	Clause(s) / subclause(s) of this EN	Remarks / Notes
	8.3.7 8.3.8 8.3.9 8.3.10 8.3.11 8.3.15	
Part I, (2).(f)	8.3.3 8.3.4 8.3.5 8.3.7 8.3.8 8.3.9 8.3.10 8.3.11 8.3.12 8.3.15	
Part I, (2).(g)	8.2.1	
Part I, (2).(h)	8.2.1 8.2.2 8.3.3 8.3.4 8.3.5 8.3.7 8.3.13 8.3.15	
Part I, (2).(i)	8.2.1 8.2.2 8.3.1 8.3.2 8.3.3 8.3.4 8.3.5 8.3.7 8.3.15	
Part I, (2).(j)	8.2.1	
Part I, (2).(k)	8.2.1 8.3.7 8.3.13 8.3.15	
Part I, (2).(l)	8.3.12	
Part I, (2).(m)	8.3.6 8.3.10	

Essential Requirements of Regulation (EU) 2024/2847	Clause(s) / subclause(s) of this EN	Remarks / Notes
Part II, (1)	Clause 7	
Part II, (2)	Clause 7	
Part II, (3)	Clause 7	
Part II, (4)	Clause 7	
Part II, (5)	Clause 7	
Part II, (6)	Clause 7	
Part II, (7)	Clause 7	
Part II, (8)	Clause 7	

1840 **WARNING 1** — Presumption of conformity stays valid only as long as a reference to this European Standard is
 1841 maintained in the list published in the Official Journal of the European Union. Users of this standard should
 1842 consult frequently the latest list published in the Official Journal of the European Union.

1843 **WARNING 2** — Other Union legislation may be applicable to the product(s) / [service(s)] / [...] falling within the
 1844 scope of this standard.

Draft

Bibliography

- [1] prEN 40000-1-2:2025, *Cybersecurity requirements for products with digital elements – Part 1-2: Principles for cyber resilience*
- [2] EN 18037:2025, *Guidelines on a sectoral cybersecurity assessment*
- [3] ENISA European Cybersecurity Certification Group Sub-group on Cryptography, *Agreed Cryptographic Mechanisms*
- [4] NIST SP 800-63B, *Digital Identity Guidelines - Authentication and Lifecycle Management*
- [5] EN ISO/IEC 27002:2022, *Information security, cybersecurity and privacy protection - Information security controls (ISO/IEC 27002:2022)*
- [6] EN ISO/IEC 24760 (all parts), *IT Security and Privacy - A framework for identity management*
- [7] ETSI EN 303-645, *Cyber Security for Consumer Internet of Things - Baseline Requirements*
- [8] GPT_SPE_150:2025, *GlobalPlatform Technology SESIP Profile for Secure MCUs and MPUs*
- [9] GPS_SPE_112:2025, *GlobalPlatform Technology PSA Certified™ Level 2 SESIP Profile (JSADEN012)*
- [10] GPS_SPE_111:2025, *GlobalPlatform Technology PSA Certified™ Level 3 SESIP Profile (JSADEN011)*
- [11] EN 17927:2023, *Security Evaluation Standard for IoT Platforms (SESIP). An effective methodology for applying cybersecurity assessment and re-use for connected products.*
- [12] EN ISO/IEC 15408-2:2023, *Information security, cybersecurity and privacy protection - Evaluation criteria for IT security - Part 2: Security functional components (ISO/IEC 15408-2:2022)*
- [13] EN ISO/IEC 15408-3:2023, *Information security, cybersecurity and privacy protection - Evaluation criteria for IT security - Part 3: Security assurance components (ISO/IEC 15408-3:2022)*
- [14] EN 17640:2022, *Fixed-time cybersecurity evaluation methodology for ICT products*
- [15] EUCC Scheme state-of-the art document, *Application of attack potential to smartcards and similar devices*
- [16] GPS_SPE_104:2025, *GlobalPlatform Technology PSA Certified™ Attack Methods (JSADEN004)*

Why do you have to pay for a standard?

Standards are agreements for and by the market. They are agreements about matters that concern everyone, e.g. about healthcare, financial services, safety and corporate social responsibility. Life would be a lot more complex without these agreements. Standards improve products, services and processes in the workplace, in our interactions with each other, and in society as a whole.

The agreements are made by interested parties. An interested party can be a producer, entrepreneur, service provider or user, but it can also be a government authority, a consumer association or a research organization. Broad support is important. The agreements are made with support from NEN, and they must not conflict with any other valid NEN standards.

NEN is a non-profit foundation. The services provided by NEN – from bringing parties together and making and recording the agreements, to providing assistance when applying the standards – cost money. That is why all the participating parties pay for the standardization process and you, as a user, pay for the standards, training courses and other products.

Ontwerp
Draft

Ontwerp
Draft